c. Summary Of Observation

3. Detailed Audit Controls

3.1. Identity Verification Controls

3.1.1. Guidelines for maintaining eKYC account by CA

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
eKYC for foreign applicants							
3.1.1.1	During the validity period of eKYC account, a fresh video verification shall have carried out for each DSC issuance within last 2 days	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC	Mandatory	IVG Sect. 2.6	Yes	3.1.1.1-792	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh

		applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.2	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA. Except in the case of mobile number verification, OTP can be sent to the email of the eKYC user.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment.	Mandatory	IVG Sect. 2.6			

CCA IVG AUDIT REPORT

		7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.3	In case of any change in account holder's information after activation of account, CA shall carry out a fresh enrollment.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

3.1.1.4	CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.	Mandatory	IVG Sect. 2.6			
3.1.1.5	For telephonic verification, CA can also verify over telephonic call, where CA originates to or	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned	Mandatory	IVG Sect. 2.6			

CCA-I AUDIT REPORT

	receives the call from the mobile number under verification, and validates the number holder with at least 2 questions establishing relation to DSC application	copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.6	The video verification shall be carried out by CA as per Annexure VI of IVG. All the originals shall be verified during the video verification. The telephonic verification shall be carried out by direct call to the	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and	Mandatory	IVG Sect. 2.6			

CCA IN AUDIT REPORT

	applicant or SMS OTP verification and the proof of verification shall be recorded. Email shall also be verified by CA.	letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.7	For Personal certificate, a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport can be submitted. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

	address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address can be provided	reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.8	For organisational person certificate, a) Scanned copy of Organisational id, Organisational email id, mobile number, Organisational address and letter of authorization from organisation are required. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry shall	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

	be provided. c) If the organisation is already registered/empanelled in government organizations of India, then the scanned copy of the letter of request issued from Indian government organisation with the details of DSC applicant can be accepted as address proof/existence of organisation for DSC issuance.	Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.9	For all categories of applicants, email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address are required to be submitted to CA.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India,	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

		- The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.1.1.10	This section is applicable only for foreign applicants who submit the KYC information to CA directly. An applicant is deemed as foreign applicant if the address (residential or organizational) provided in the DSC application form does not belong to India or identity document submitted is not issued by authorities under Government of India.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of	Mandatory	IVG Sect. 2.6			

CCA IN AUDIT REPORT

		Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
PAN eKYC for Personal Certificates							
3.1.1.11	For DSC issuance, video verification shall have carried out within last 2 days	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

		verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.1.1.12	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			

COA - AUDIT REPORT

3.1.1.13	In case of any change in account holder's information after activation of account, CA shall carry out fresh enrollment.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			
3.1.1.14	CA activates eKYC account after mobile, email, PAN and video verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

		verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.1.1.15	The eKYC account request shall include Name (as in PAN), residential address (as in address id), photo, PAN, mobile no, email etc.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN	Mandatory	IVG Sect. 2.5			

CCA INDIA AUDIT REPORT

		verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.1.1.16	CA shall verify the Government ID having address submitted to CA against the original displayed during the video verification.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			

COA - AUDIT REPORT

3.1.1.17	CA shall electronically verify the PAN number with Income tax database through eKYC service and accept only if the name is matching correctly. The digitally signed proof of the verified response shall be preserved by CA.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			
3.1.1.18	The video verification of the applicant shall be carried out by CA as per Annexure VI of IVG. During the video verification, the applicant shall display original PAN card and Government ID having address for cross verification by CA. Both the PAN details and address in the Id captured in the video shall be in a clear and readable form.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video	Mandatory	IVG Sect. 2.5			

COMPLIANCE AUDIT REPORT

		verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.1.1.19	The mobile number should be registered in the name of the eKYC applicant and the same shall be verified by CA through the services provided by Telecom companies. Or CA should use the banking penny drop process to cross verify (exact or reasonable match) the name of the DSC applicant with the name registered in the bank account. The proof of the verification shall be preserved.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN	Not Applicable				

CCA INDIA AUDIT REPORT

		verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.1.1.20	CA shall carryout verification of Mobile Number and PAN(eKYC).	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			

COA - AUDIT REPORT

3.1.1.21	This section is applicable only for persons who submit the PAN & other KYC information to CA directly. The mobile number, PAN of the applicant and Government ID having address (Annexure IV) are mandatory. The scanned copy of the PAN card and Government ID having address shall be submitted to CA	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			
Banking eKYC for Banking Customers							
3.1.1.22	For each DSC issuance, CA shall have received KYC of the account holder from the Bank within last 24 hours.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name,	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.23	CA shall accept the mobile number within bank KYC only, no changes are allowed	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.1.1.24	If email is not present in the KYC provided by Bank, the same can be	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

	captured by CA and shall accept only after verification.	signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.25	CA activates eKYC account after mobile verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.26	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.1.1.27	The mobile number and PAN/Aadhaar Number(last four digit) of the applicants are mandatory	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.28	The KYC details shall include Name, address, photo, PAN/Aadhaar Number, mobile no, Bank account No, Bank IFSC code (if applicable).	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.1.1.29	The DSC to be used for signature by bank shall be registered with CA and shall be mapped with the bank ID/Name	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.30	CA shall carry out verification of existence of Bank, authorised signatory's identity as mentioned in Annexure I of the Identity Verification guidelines	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.31	CA shall have an agreement/undertaking with Bank.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.1.1.32	CA shall verify the source of the request and signature of bank prior to accept KYC information	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.1.1.33	This section is applicable only for persons having Banking account and Banks submit the KYC of the Banking Customer to CA directly after obtaining consent and authentication from the customer. The video verification is not mandatory.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
Verification of Authorised Signatory							
3.1.1.34	In case the company is a single director company with no other authorized signatories, or a proprietorship organization, it can be considered for self-authorization, provided that Information is	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of	Mandatory	IVG Sect. 2.3.1			

CCA AUDIT REPORT

	verified in MCA website. In case of proprietorship organization where applicant himself/herself is the proprietorship, self authorization / no authorization is required.	IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.					
3.1.1.35	Upon successful confirmation of organizational identity of authorised person, CA shall create an eKYC account and may issue DSC to authorised signatory. The DSC/eKYC Account of the authorized signatory shall be registered with CA and shall be mapped with the name of the verified organisation. Subsequently all the information submitted by eKYC applicant for eKYC account shall be digitally signed by authorised signatory. The DSC of the authorised signatory shall be asserted with OID 2.16.356.100.10.3 in the policy id field along with policy id for class of certificate	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.	Mandatory	IVG Sect. 2.3.1			
3.1.1.36	CA shall also carryout secondary verification like face-to-face interaction/web site reference/call to organizational telephone numbers to confirm the organizational identity of authorised person and the proof of the verification shall be maintained.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face	Mandatory	IVG Sect. 2.3.1			

CCA - AUDIT REPORT

		interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.					
3.1.1.37	The steps 4-7 of 2.3 shall be followed for the verification prior to the eKYC account creation.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.	Not Applicable				
3.1.1.38	The scanned copy of the documents for existence of organization & authorization to authorized signatories as per Annexure I of IVG shall be submitted to CA and the originals shall be verified during video verification.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person.	Mandatory	IVG Sect. 2.3.1			

CCA - AUDIT REPORT

		4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.					
Organisational KYC for Organisational Person Certificates							
3.1.1.39	For DSC issuance, the video verification shall have carried out within last 2 days	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information	Mandatory	IVG Sect. 2.3			

CCA IOT REPORT

		accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.40	CA shall accept the mobile number within Organisational KYC only, no changes are allowed.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of	Mandatory	IVG Sect. 2.3			

CCA IT AUDIT REPORT

		DSC issuance					
3.1.1.41	In case of any change in account holder's status or information, the request for change shall be submitted with the authorization of authorised signatory.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance	Mandatory	IVG Sect. 2.3			
3.1.1.42	CA shall provide Organizational eKYC applicant to set up PIN and user ID upon the	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming	Mandatory	IVG Sect. 2.3			

CCA - AUDIT REPORT

	authentication by CA.	convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.43	CA activates eKYC account after mobile, email and PAN verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

		the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.44	CA shall carry out interactive video verification as per Annexure VI and shall verify the photo match of eKYC photo with the video. The original document verification is also a part of video verification. The in-person verification can also be substituted by Aadhaar eKYC Biometric Authentication provided that CA successfully verifies the face in Aadhaar Photo against	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the	Mandatory	IVG Sect. 2.3			

CCA - AUDIT REPORT

	that in KYC record.	eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.45	The eKYC account request shall include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. Them mobile number and PAN of the applicants are mandatory. The copy of the organisational ID card and PAN shall also be submitted to CA	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN,	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

		mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.46	KYC of organisational eKYC applicant shall be submitted to CA and CA carryout the verification.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

		and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.47	The criteria for the eligibility of government organisation and its authorised signatory are given in the annexure V of IVG	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document	Not Applicable				

CCA AUDIT REPORT

		verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.48	CA shall carry out the verification of the existence of organization & authorised signatory of the organization as per IVG. All the information submitted by eKYC applicant for eKYC account shall be digitally signed by authorised signatory.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.3			

CCA IT AUDIT REPORT

		15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.49	The minimum requirements for Issuance of DSC to organisation person include: a) eKYC account of Applicant b) Applicant ID Proof or Proof of individuals association with organisation c) Letter of Authorization by Organization to Authorized Signatory for self authorisation and also to other DSC applicants. d) eKYC account of Authorized Signatory and authorization to DSC applicant e) Proof of existence of organization	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory.	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

		17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.1.1.50	For organisational person certificate, the Organization Name (O Value) in the certificate shall match the organization name and also in compliance with naming convention specified CCAIOG	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Aadhaar offline eKYC							
3.1.1.51	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.1.1.52	For each DSC issuance, video verification shall have carried out within last 2 days	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

		subscriber agreement with eKYC applicant.					
3.1.1.53	CA does interactive video verification (Annexure VI) and also does a photo match of Aadhaar eKYC photo with the video.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.1.1.54	If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, CA shall verify the same prior to inclusion in the eKYC account.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance	Mandatory	IVG Sect. 2.2.2			

CCA - AUDIT REPORT

		9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
3.1.1.55	For issuance of DSC, CA captures email for communications, alerts, and PIN reset options and it must be verified.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.1.1.56	CA shall accept the mobile number within offline KYC only, no changes are allowed.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

		carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
3.1.1.57	CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.1.1.58	Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" which is used to encrypt the offline KYC XML.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match	Mandatory	IVG Sect. 2.2.2			

CCA - AUDIT REPORT

		of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
Aadhaar online eKYC – Biometric							
3.1.1.59	For each DSC issuance, Aadhaar eKYC Biometric authentication of applicant shall have carried out within last 2 days and CA should accept only if the face in Aadhaar Photo matches against that in CA eKYC record of same applicant. The in-person verification can also be substituted by interactive video verification (Annexure VI) provided that CA should successfully verifies the matching face in video with the photograph of eKYC record of the same applicant.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...	Mandatory	IVG Sect. 2.2.1.2			
3.1.1.60	The mobile number is mandatory. CA shall capture the mobile number of the applicant and carryout verification of Mobile Number.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...	Mandatory	IVG Sect. 2.2.1.2			
3.1.1.61	Up on successful authentication, CA receives Aadhaar e-KYC XML and creates e-KYC account for applicant.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of	Mandatory	IVG Sect. 2.2.1.2			

CCA AUDIT REPORT

		Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...					
3.1.1.62	Subscriber submits Aadhaar Number and performs biometric authentication through the interface provided by CA to UIDAI.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC	Mandatory	IVG Sect. 2.2.1.2			
Aadhaar online eKYC – OTP							
3.1.1.63	For each DSC issuance, video verification shall have been carried out within last 2 days. The in-person verification can also be substituted by Aadhaar Biometric Authentication.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.1.1.64	CA does interactive video verification (Annexure VI) and also does a photo match of Aadhaar eKYC photo with the video.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.1.1.65	The mobile number is mandatory. CA shall capture the mobile number of the user and carryout verification of Mobile Number.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by	Mandatory	IVG Sect. 2.2.1.1			

CCA AUDIT REPORT

		subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.					
3.1.1.66	Up on Successful authentication, CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.1.1.67	Subscriber submits Aadhaar Number and performs provides OTP authentication through the interface provided by CA to UIDAI.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
Aadhaar online eKYC							
3.1.1.68	Subscriber sets up initial PIN and user ID.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

		included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
3.1.1.69	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	null	Mandatory	IVG Sect. 2.2.1			
3.1.1.70	For DSC issuance, email shall be included in the eKYC account after verification by CA	null	Mandatory	IVG Sect. 2.2.1			
3.1.1.71	On successful Aadhaar eKYC Authentication for the eKYC Account, CA shall store the unique UID Token for that Aadhaar holder against such eKYC Account. This shall be used for referring to same user during any re-verification requirements.	null	Mandatory	IVG Sect. 2.2.1			
3.1.1.72	If PAN of the applicant is to be included in eKYC account for embedding it in the certificate, CA shall verify the same prior to inclusion in the eKYC account.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information.	Mandatory	IVG Sect. 2.2.1			

CCA IT AUDIT REPORT

		7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.73	The application should be signed by DSC applicant. The verified information received through e-KYC services can be used for obtaining eSign of DSC applicant by CA through a separate user eKYC authentication.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.74	The DSC application form should be generated by populating the information received from UIDAI.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.75	The verified information received through online Aadhaar e- KYC shall be used for creation eKYC account of user.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.76	Up on receipt of Aadhaar eKYC XML from UIDAI, CA decrypts, validates UIDAI signature, reads and extracts demographic data, and photo.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.77	In the case of online Aadhaar Biometric/OTP-based eKYC account enrollment, in addition to the UIDAI requirements a) CA shall ensure that the applicant is already authenticated and started a session as per 1.3(3). b) CA shall start a new session and redirect the user to the dedicated CA interface page for capturing authentication information. (Aadhaar no, Biometric or OTP, consent, etc) . c) For each eKYC request to UIDAI, CA should implement validations at the server side which shall include parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. d) Only one Aadhaar authentication shall be processed per one session and session time shall be limited to 10 minutes. e) The Aadhaar Number shall not be displayed on the user interface. Only the Name, Last four digits of the Aadhaar and photo shall be displayed to the DSC applicants. f) CA shall look for any external sites linking to them in an unauthorized manner and consuming the purpose by spoofing or scraping the CA	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

	website/application. CA shall ensure that they use captcha implementation or similar security to avoid automated attacks and ensure only a human is doing the process on CA enrolment application steps. The request for Aadhaar authentication shall only be accepted directly from the CA-controlled application.						
3.1.1.78	CA shall be an authorized e-KYC User Agency (KUA) of Unique Identification Authority of India (UIDAI).	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.1.1.79	This section is allowed as per the OM(File No. 13(6)/2018-EG- II(Pt)), dated 18 Jan 2022 , to use Aadhaar e-KYC authentication by Certifying Authorities under the CCA for issue of Digital Signature Certificate (DSC) under Section 3A of the IT Act along with the e-signature also in compliance with Section 4(4)(b)(i) of the Aadhaar Act, 2016 as amended.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		with eKYC applicant					
Aadhaar e KYC							
3.1.1.80	As part of the e-KYC process prescribed by UIDAI under Aadhaar Act, the applicant for DSC authorizes CA (through Aadhaar eKYC) to obtain their demographic data along with his/her photograph (digitally signed and encrypted) to CAs for verification.	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
3.1.1.81	CAs are required to follow the requirements specified by UIDAI strictly for eKYC authentication of DSC applicant	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
3.1.1.82	These guidelines are intended to be used to create eKYC account who have Aadhaar Number registered in UIDAI Database.	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
Authentication for eKYC Account							
3.1.1.83	As a part of KYC, before activation, subscriber shall set PIN and "user ID" a) The eSign Address is in the form "@.". b) The ESP-ids are eMudhra, nCode, CDAC, Capricorn, NSDLeGov etc. id-types are mobile number, PAN and username. c) To ensure ease of use by subscribers, it is recommended that CA shall keep user name limited to few characters. d) CA shall ensure username is unique within their system. For Personal eKYC accounts, the mobile number and PAN shall be unique.	null	Mandatory	IVG Sect. 2.1			
3.1.1.84	CA to verify the applicant one time and issue DSC subsequently	Conduct a walkthrough of the eKYC facility and check the following: 1. CA verifies the applicant and issued	Mandatory	Identity Verification Guidelines (IVG) Section 2.1			

CCA - AUDIT REPORT

	based on 2-factor authentication by applicant. The two factor authentication includes the PIN set by the applicant and a second factor, as permitted by the guidelines issued by CCA. (Eg: OTP sent to the verified mobile)	DSC based on 2-factor authentication by applicant 2. The two factor authentication includes the PIN set by the applicant and a second factor, as permitted by the guidelines issued by CCA. (Eg: OTP sent to the verified mobile) 3. Subscriber sets the PIN and UserID as mentioned in control 3.5.6.2					

3.1.2. General Guidelines to CAs

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Additional Physical verification							
3.1.2.1	The authorised person employed by the CA shall also verify the possession and proof of registration of the mobile number, address proof, identity, ink signature verification, neighborhood enquiry etc. or any additional requirements to eliminate the possibility of impersonation.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Not Applicable				
3.1.2.2	For highest level of assurance, in addition to all the requirements mentioned in this document, an authorised person employed by the CA shall verify the physical presence of DSC applicant and also verify the genuineness of all the documents submitted.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Mandatory	IVG Sect.1.25			
3.1.2.3	The additional physical verification of DSC applicant is optional, however if opted the OID 2.16.356.100.10.2 shall be mentioned in the policy id field of certificate.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Mandatory	IVG Sect.1.25			
Registration Authorities(RAs							
3.1.2.4	The role of RA is strictly restricted as a business partner. For business-related accounting purposes, the reference	1. Verify whether CA software has any interface to RA.	Mandatory	IVG Sect.1.24			

CCA - AUDIT REPORT

	code of RA may be included in the DSC applicant's interface.						
SMS-OTP							
3.1.2.5	OTP shall be sent only to the verified mobile number registered in the eKYC account.	1. Validate CA always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for 2. Verify whether the OTP is a newly generated random number for each transaction. 3. Validate OTP is sent only to the verified mobile number registered in the eKYC account.	Mandatory	IVG Sect.1.23			
3.1.2.6	CA shall always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for. OTP should be a newly generated random number for each transaction.	1. Validate CA always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for 2. Verify whether the OTP is a newly generated random number for each transaction. 3. Validate OTP is sent only to the verified mobile number registered in the eKYC account.	Mandatory	IVG Sect.1.23			
Second factor Authentication							
3.1.2.7	The eKYC account shall be activated using PIN and OTP. Subsequently other authentication can be used in place of OTP however OTP shall be retained as a fallback option.	1. Validate second factor authentication is SMS-OTP or the other authentication mode specified in the eSign API 2. Validate eKYC account is activated using PIN and OTP only.	Mandatory	IVG Sect.1.21			
3.1.2.8	The second factor authentication can be SMS-OTP or the other authentication mode specified in the eSign API	1. Validate second factor authentication is SMS-OTP or the other authentication mode specified in the eSign API 2. Validate eKYC account is activated using PIN and OTP only.	Mandatory	IVG Sect.1.21			
First factor Authentication							
3.1.2.9	The first factor authentication to eKYC account shall be PIN	1. Validate first factor authentication to eKYC account is PIN	Not Applicable				
Encryption Certificate							
3.1.2.10	The encryption keys and certificates shall be preserved by subscriber also.	1. Check for encryption certificates, CA provides key escrow facility, where key pair is securely stored and managed . 2. Check the key is retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. 3. Check escrowed key is retained by CA for minimum of 7 years from the expiry of the certificate from Jan 01, 2021	Mandatory	IVG Sect.1.20			

CCA AUDIT REPORT

		onwards. 4. Check CA allows the download of the escrowed key only after a successful video verification of the applicant. 5. Validate CA allows subscriber to download encryption keys and certificates for preservation, also.					
3.1.2.11	For encryption certificates, CA shall provide key escrow facility, where key pair is securely stored and managed by CA. The key shall be retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. This shall be retained by CA for minimum of 7 years from the expiry of the certificate. CA shall allow the download of the escrowed key only after a successful video verification of the applicant.	1. Check for encryption certificates, CA provides key escrow facility, where key pair is securely stored and managed . 2. Check the key is retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. 3. Check escrowed key is retained by CA for minimum of 7 years from the expiry of the certificate from Jan 01, 2021 onwards. 4. Check CA allows the download of the escrowed key only after a successful video verification of the applicant. 5. Validate CA allows subscriber to download encryption keys and certificates for preservation, also.	Mandatory	IVG Sect.1.20			
Special purpose certificates							
3.1.2.12	Only organisational persons are allowed to apply for special purpose certificate.	1. Validate, apart from the details required for creation of eKYC account, the additional details is verified by CA in accordance with the type of special purpose certificate. 2. Validate that only organisational persons are allowed to apply for special purpose certificate	Mandatory	IVG Sect.1.19			
3.1.2.13	Apart from the details required for creation of eKYC account, the additional details shall be verified by CA in accordance with the type of special purpose certificate.	1. Validate, apart from the details required for creation of eKYC account, the additional details is verified by CA in accordance with the type of special purpose certificate. 2. Validate that only organisational persons are allowed to apply for special purpose certificate	Mandatory	IVG Sect.1.19			
Role of Trusted person							
3.1.2.14	CA trusted person/Verification Officer shall approve and certify each account information including name timestamp etc. using their own digital signature	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/	Mandatory	IVG Sect.1.18			

CCA AUDIT REPORT

		Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.					
3.1.2.15	All the CA Verification Officers shall be exclusive employees of the CA and shall not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance.	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/ Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.	Mandatory	IVG Sect.1.18			
3.1.2.16	CA shall make sure that the CA Verification Officer's roles and responsibilities are not be delegated or controlled by anyone else.	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/ Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.	Mandatory	IVG Sect.1.18			
Archival							
3.1.2.17	Archival of information shall be 7 years from the date of expiry of the Digital Signature Certificate	1. Check digitally signed documents, proof of verification information, logs etc. are preserved and archived by CA as per Act. 2. Check on sample basis archival information of the Digital Signature Certificate is available for 7 years from	Mandatory	IVG Sect.1.17			

CCA AUDIT REPORT

		the date of its expiry.					
3.1.2.18	CAs shall preserve the digitally signed documents, proof of verification information, logs etc. as per the requirements mentioned in the Information Technology Act.	1. Check digitally signed documents, proof of verification information, logs etc. are preserved and archived by CA as per Act. 2. Check on sample basis archival information of the Digital Signature Certificate is available for 7 years from the date of its expiry.	Mandatory	IVG Sect.1.17			
DSC Issuance							
3.1.2.19	DSC shall be issued only up on satisfying the verification requirements specified in the respective eKYC sections in this document. The maximum time limit for the download of DSC shall be 30 days from the date of completion of verification/approval. If the download of DSC is not carried out by the applicant within 30 days, applicable verification requirements specified in the respective eKYC sections in this document shall be carried out by CA before DSC issuance	1. Validate maximum time limit for the download of DSC is 30 days from the date of completion of verification/ approval. 2. Verify on sample basis, if the download of DSC is not carried out by the applicant within 30 days, applicable verification specified in the respective eKYC sections of IVG is carried out by CA before DSC issuance	Mandatory	IVG Sect.1.16			
Subscriber Agreement							
3.1.2.20	For eKYC account creation based on the KYC information source such as Offline Aadhaar KYC, Banking and organisational , the eSign of the subscriber shall be based on the information received from the KYC information source.	2. Validate, for eKYC account creation based on the KYC information source such as Offline Aadhaar KYC, Banking and organisational , the eSign of the subscriber is based on the information received from the KYC information source	Mandatory	IVG Sect.1.15			
3.1.2.21	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	1. Validate CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	Mandatory	IVG Sect.1.15			
Invoice/Acknowledgement							
3.1.2.22	To ensure there is no tax evasion in the DSC issuance service a) For Personal Digital Signature Certificate	1. Check Tax invoices are issued by CA as per the requiremenrs 2. Check CA has provided option for the online payment 3. Check the reconciliation report	Mandatory	IVG Sect.1.14			

CCA - AUDIT REPORT

	issuance (Class 3), CA shall generate, issue and send the GST tax invoice to the DSC applicant through email. b) For Organizational Person Digital Signature Certificate issuance (Class 2 and Class 3), CA shall generate, issue and send the GST tax invoice to the DSC applicant or applicant's organization through email. c) Except in the case of organisation person certificate through the organization, GeM, tender, person authorized by the organization, etc, CA shall not accept the payment towards DSC issuance in advance, directly or indirectly, causing financial liability in any manner, before the mobile authentication of the DSC applicant. CA shall carry out periodic reconciliation of invoices with corresponding DSC issued to subscribers. The copy of the TAX invoice shall be preserved by CA. The applicant's interface software should be integrated with the payment gateway for accepting fees from DSC applicants for the issuance of certificates.	generated by CA. 4. Verify the TAX invoices have been preserved by CAs 5. Verify the proof of sending TAX invoice via email to the DSC applicant.					
Key pair generation/Storage							
3.1.2.23	For personal signing certificates, subscribers' key generation shall be strictly using the software provided by CA and shall not be generated outside of the crypto device.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against "PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2	Mandatory				

CCA AUDIT REPORT

		Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.1.2.24	In respect of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk shall be made known to the DSC applicant and an undertaking shall be taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

		for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.1.2.25	A list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens must be published on the website of the CA.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3	Mandatory	IVG Sect.1.13			

CC AUDIT REPORT

		Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.1.2.26	For protection of crypto token against “PIN reset compromise , a) CA shall not support PIN reset procedure for subscriber’s crypto token, unless the crypto token is re- initialized / formatted. For the convenience of DSC applicant on such scenarios, CA shall re-issue the certificate for the remaining period of validity of the certificate. Such re-issuance shall be provided free of cost, at least once per certificate. CA may provide additional re-issuance which may be charged extra by CA to the user. CA shall carryout such re-issuance only after authentication of the subscriber. b) From 01.04.2023 onwards, CA shall not allow the download of DSC to crypto token having default password.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM	Mandatory	IVG Sect.1.13			
3.1.2.27	CA shall put procedure in	1. Verify CA not issues any class 2 level	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

	place to ensure that no Class 3 individual Signing DSCs are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens).	individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.1.2.28	CA shall issue class 3 level individual signing certificate (both Personal & organizational) to the private key generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens) with both Class 2 and Class 3 OID in the policy field. CA shall not issue class 2 level individual Signing	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto	Mandatory	IVG Sect.1.13			

CCA IT AUDIT REPORT

	certificates alone instead CA shall issue Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. Class 3 individual signing certificates shall be qualified as both class 2 & class 3 individual signing certificates.	tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.1.2.29	Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs shall be as per annexure II. For individual signing certificates, the CA should verify the validity of the Key attestation by HSM and also verify no certificates with different DN have been issued earlier.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

		Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
Documents verification							
3.1.2.30	For the digitally signed documents received from the issuing authority or the same fetched through Digi locker by CA, further verification of supporting documents through video is not required.	Verify whether the documents fetched through Digilocker bearing the electronic signature of the issuer	Mandatory	IVG Sect.1.12			
3.1.2.31	Using online verification, CA shall verify the authenticity of the document submitted and the digitally signed proof of the online verification shall be maintained.	Verify whether CA is verifying the authenticity of the documents through online process and proof retained	Mandatory	IVG Sect.1.12			
3.1.2.32	The video verification of the original documents shall be carried out as per Annexure VI	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents 2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG	Mandatory	IVG Sect.1.12			

CCA AUDIT REPORT

3.1.2.33	If applicable, the originals of the identity and address proof shall be verified during the video verification.	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents 2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG	Mandatory	IVG Sect.1.12			
3.1.2.34	In lieu of the attestation of documents exists in the paper- based DSC application; CA shall verify the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents 2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG	Mandatory	IVG Sect.1.12			
Physical verification/Video verification							
3.1.2.35	CA shall check any indication of alteration or falsification in video recording	1. Validate physical verification of DSC applicant is carried out using online interactive video verification directly by CA as per Annexure VI of IVG or by online Aadhaar eKYC Biometric Authentication 2. Verify CA checks any indication of alteration or falsification in video recording	Mandatory	IVG Sect.1.11			
3.1.2.36	The physical verification of DSC applicant shall be carried out using online interactive video verification directly by CA as per Annexure VI or by online Aadhaar eKYC Biometric Authentication	1. Validate physical verification of DSC applicant is carried out using online interactive video verification directly by CA as per Annexure VI of IVG or by online Aadhaar eKYC Biometric Authentication 2. Verify CA checks any indication of alteration or falsification in video recording	Mandatory	IVG Sect.1.11			
Verification							
3.1.2.37	CA shall allow only the automatic population of digitally signed information received from source of eKYC like Aadhaar or Bank in the electronic application form. The information received from the other source (like PAN and	1. Validate verification for the purpose of creating an eKYC account with CA for eSign or DSC issuance is the electronic verification of the identity and nformation submitted by eKYC applicant. 2. Validate CA allow only the automatic population of digitally signed information received from source of eKYC . 3. The information received from the	Mandatory	IVG Sect.1.10			

COMPLIANCE AUDIT REPORT

	GSTN) shall be used only for cross verifying the information submitted by the applicant in the interface provided by CA.	other source (like PAN and GSTN) is only used for cross verifying the information submitted by the applicant in the interface provided by CA.					
3.1.2.38	Verification is the electronic verification of the identity and information submitted by eKYC applicant for the purpose of creating an eKYC account with CA for eSign or DSC issuance.	1. Validate verification for the purpose of creating an eKYC account with CA for eSign or DSC issuance is the electronic verification of the identity and nformation submitted by eKYC applicant. 2. Validate CA allow only the automatic population of digitally signed information received from source of eKYC . 3. The information received from the other source (like PAN and GSTN) is only used for cross verifying the information submitted by the applicant in the interface provided by CA.	Mandatory	IVG Sect.1.10			
PAN							
3.1.2.39	CA shall electronically verify the PAN number through the eKYC service provided by Income tax and accept only if the verification is successful, the name of the PAN holder and Date of Birth match and also the Aadhaar seeding status is operative. CA shall preserve the proof of verification with their digital signature.	1. Validate CA electronically verifes the PAN number with Income tax database through eKYC service and accept only if the verification is successful, the name of the PAN holder and Date of Birth match and also the Aadhaar seeding status is operative. 2. Verify CA preserve the proof of verification with their digital signature	Mandatory	IVG Sect. 1.9			
Email Address							
3.1.2.40	No disposable email (fast temporary email without registration) shall be accepted by CA.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.1.2.41	For email verification, CA shall send an email OTP or challenge	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA.	Mandatory	IVG Sect. 1.8			

CCA - AUDIT REPORT

	response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors shall be random, communicated only to the email ID under verification, and shall not be based on any predetermined parameters to avoid the compromise. CA should preserve the proof of verification with their digital signature	2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA					
3.1.2.42	Provisions can be made for issuance of multiple DSC with a single email Id where it is established that these multiple DSCs are being issued to same DSC applicant.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.1.2.43	CAs shall put in measures to ensure that email addresses that are included in Digital Signature Certificates (DSC) are unique to the DSC applicant.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.1.2.44	Email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. Email id is optional for the eKYC accounts activated only for the purpose of eSign	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided	Mandatory	IVG Sect. 1.8			

CCA AUDIT REPORT

		by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA					
Mobile Number							
3.1.2.45	For the proof possession of mobile number, CA shall send a SMS OTP and the same shall be verified by capturing through the interface provided by CA. Such verification OTP shall be random, communicated only to the mobile number under verification, and shall not be based on any predetermined parameters to avoid the compromise.	1. Mobile number is mentioned as mandatory pre-requisite for creation of eKYC account by CA 2. Validate CA send a SMS OTP for the proof of possession of mobile number and the same is verified by capturing through the interface provided by CA. Such verification OTP is random, communicated only to the mobile number under verification, and is not based on any predetermined parameters to avoid the compromise.	Mandatory	IVG Sect. 1.7			
3.1.2.46	Mobile Number of applicant is a pre-requisite for creation of eKYC account by CA for applicant.	1. Mobile number is mentioned as mandatory pre-requisite for creation of eKYC account by CA 2. Validate CA send a SMS OTP for the proof of possession of mobile number and the same is verified by capturing through the interface provided by CA. Such verification OTP is random, communicated only to the mobile number under verification, and is not based on any predetermined parameters to avoid the compromise.	Mandatory	IVG Sect. 1.7			
Address							
3.1.2.47	For address proof, the applicable list of documents are given in Annexure IV	1. Validate residential or organizational address be provided 2. Verify address proof of DSC applicant as per IVG collected.	Mandatory	IVG Sect. 1.6			
3.1.2.48	The address of the DSC applicant shall be residential or organisational.	1. Validate residential or organizational address be provided 2. Verify address proof of DSC applicant as per IVG collected.	Mandatory	IVG Sect. 1.6			
Name							
3.1.2.49	For proof of Identity, copy of at least one photo Identity proof bearing name of the applicant , as mentioned in the Annexure IV , shall be	1. Validate name of the DSC applicant is same as the name in respective eKYC 2. Verify proof of Identity, copy of at least one photo Identity proof bearing name of the applicant as per IVG has	Mandatory	IVG Sect. 1.5			

CCA - AUDIT REPORT

	submitted	been collected.					
3.1.2.50	The name of the DSC applicant shall be same as the name in respective eKYC	1. Validate name of the DSC applicant is same as the name in respective eKYC 2. Verify proof of Identity, copy of at least one photo Identity proof bearing name of the applicant as per IVG has been collected.	Mandatory	IVG Sect. 1.5			
Mandatory Information in the DSC application Form							
3.1.2.51	For all categories of DSC applicants, it is mandatory to provide either PAN or Aadhaar Number.	1. Verify for mandatory information i.e., Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal organisational), signature of applicant and Class in the eKYC account and DSC application form for issuance of DSC. 2. Verify either PAN or Aadhaar Number taken for all categories of DSC applicants.	Mandatory	IVG Sect. 1.4			
3.1.2.52	Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal/organisational), signature of applicant and Class are mandatory in the eKYC account and DSC application form for issuance of DSC. Email is optional for eKYC account to be created only for the purpose of eSign.	1. Verify for mandatory information i.e., Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal organisational), signature of applicant and Class in the eKYC account and DSC application form for issuance of DSC. 2. Verify either PAN or Aadhaar Number taken for all categories of DSC applicants.	Mandatory	IVG Sect. 1.4			
DSC Application Form							
3.1.2.53	Power of attorney is not allowed for the purpose of DSC application to CA and Issuance of DSC	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.	Mandatory	IVG Sect. 1.3			
3.1.2.54	The electronic signature of the applicant in the DSC application form shall be affixed using the eSign service of the CA.	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has	Mandatory	IVG Sect. 1.3			

CCA AUDIT REPORT

		been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.					
3.1.2.55	DSC application form shall be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant.	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.	Mandatory	IVG Sect. 1.3			
eKYC Account							
3.1.2.56	The PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.57	The format of the eKYC account ID shall be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		• Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					

CCA AUDIT REPORT

3.1.2.58	CA shall have approval of CCA for maintaining eKYC account for applicants.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.59	Appropriate fraud detection and preventive security mechanisms shall be implemented against enrollment frauds. Specifically CA should make sure that the page capturing PIN shall be free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.60	Applicant shall have an option to activate, deactivate and close account at any point.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		• Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					

CCA AUDIT REPORT

3.1.2.61	Applicant shall be able to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account maintained by CA.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.62	CA shall notify applicant the subscriber agreement for the use of KYC information for DSC issuance by CA on successful authentication by the applicant. The applicant shall have option to accept or reject the same	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.63	In case CA is not able to ascertain the genuineness of the e-KYC data submitted by applicant, CA shall reject the request	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		• Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					

CCA AUDIT REPORT

3.1.2.64	The validity of eKYC account shall not be more than 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant under these guidelines.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.65	In case eKYC account holder requires more than one account (fore.g personal and organizational), eKYC account holder must undergo all the verification procedures mentioned for the additional eKYC option. CA should treat both eKYC accounts logically under one eKYC account of the eKYC applicant. The mobile number and PAN can be the same. For user authentication, CA shall provide an option for selecting the account mode (personal/organizational)	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.66	The DSC applicant's access to the website of CA for submission of details for eKYC account creation, video verification and Online Aadhaar authentication shall be only through a single & dedicated interface provided by CA and link-based access shall not be permitted for these interfaces	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		• Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					

CCA AUDIT REPORT

3.1.2.67	For eKYC account creation, CA shall provide the interface only to the applicant. Also, CA shall not provide any provision to submit the applicant's details other than the applicant.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.68	Prior to submitting information for the eKYC account creation of an applicant, the CA shall authenticate the applicant using the applicant's mobile number and the same mobile number shall be used in the subsequent authentication also. Upon successful authentication of the applicant, start a new session for all the associated with the eKYC account creation process and continue the session till its completion. Also, the same mobile number should be a part of the eKYC account of the applicant.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.1.2.69	The eKYC account of the DSC applicant shall be created by CA based on eKYC of applicant (Bank, Organisational, PAN and Offline Aadhaar) or a direct verification (Foreign Nationals) . The information which are required in DSC application form and not present in the eKYC of applicant shall be submitted by the eKYC applicant and verified by CA before activating the eKYC account.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		• Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					

CCA AUDIT REPORT

3.1.2.70	eKYC account of DSC applicant is mandatory for applying for a DSC or availing eSign service. The verified information held by CA shall be used for issuance of DSC or eSign. For eSign service based on online Aadhaar authentication, eKYC account is not required	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
General							
3.1.2.71	The subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access shall be limited to only authorized CA personnel. Access, sharing, photographic images/video and/or retention of such information by anybody other than CA, as applicable under the provisions of IT Act, shall be liable for penalty for breach of confidentiality and privacy under section 72 of IT Act.	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.	Mandatory	IVG Sect. 1.1			
3.1.2.72	The eKYC information collected from applicant shall not be shared by CA and comply with all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.	Mandatory	IVG Sect. 1.1			

CCA AUDIT REPORT

3.1.2.73	CA shall make sure the following text shall be displayed to the user before submission / signing of DSC application form. Section 71 of IT Act stipulates that if anyone makes a misrepresentation or suppresses any material fact from the CCA or CA for obtaining any DSC such person shall be punishable with imprisonment up to 2 years or with fine up to one lakh rupees or with both	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.	Mandatory	Identity Verification Guidelines (IVG) Section 1.1			

3.1.3. Identification and authentication for re key requests

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Identification and authentication for re-key requests							
3.1.3.1	When current Signing Key is used for identification and authentication purposes, the life of the new certificate shall not exceed beyond the initial identity-proofing times specified in the table above.	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP	Mandatory	X.509 Policy 3.3.1, CA Browser Forum 3.3.1			
3.1.3.2	Identity shall be established through the initial identity- proofing process for each assurance level per the CP	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP	Mandatory	X.509 Policy 3.3.1, CA Browser Forum 3.3.1			
3.1.3.3	The CAs and subscribers shall identify themselves through use of their current Signing Key or by using the initial identity-	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and	Mandatory	X.509 Policy 3.3.1, CA BrowserForum 3.3.1			

CCA - AUDIT REPORT

	proofing process	authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP					

3.1.4. dentification and authentication for revocation request

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.5. Initial identity validation

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Initial identity validation							
3.1.5.1	Information that is not verified shall not be included in certificates.	1. Verify for Class 2 and Class 3 certificates, identity is established by in-person proofing before the CA, to confirm identities 2. Validate CA does not include any non-verified information in the certificates	Mandatory	X.509 Policy 3.2.4, CA Browser Forum 3.2.4			
3.1.5.2	For Class 2 and Class 3 certificates, identity shall be established by in-person proofing before the CA, to confirm identities; information provided shall be verified to ensure legitimacy	1. Verify for Class 2 and Class 3 certificates, identity is established by in-person proofing before the CA, to confirm identities 2. Validate CA does not include any non-verified information in the certificates	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			
3.1.5.3	The process documentation and authentication requirements shall include the following: • The identity of the person performing the identity verification; • A signed declaration by that person that he or she verified the identity of the applicant; • The applicant shall present one photo ID. The applicant shall also present a document as a proof of residential address. • Unique identifying numbers from the	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			

CCA - AUDIT REPORT

	Identifier (ID) of the verifier and from an ID of the applicant; • The date and time of the verification; and • A declaration of identity signed by the applicant using a handwritten signature or equivalent per Indian Laws.						
3.1.5.4	A CA shall ensure that the applicant's identity information i verified. The CA shall ensure that the applicant's identity information and public key are properly bound. Additionally, the CA shall record the process that was followed for issuance of each certificate. Process information shall depend upon the certificate level of assurance and shall be addressed in the applicable CPS	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			
3.1.5.5	Requests for certificates in the name of an organizational user shall include the user name, organization name, address, and documentation of the existence of the organization. The CA shall verify the information relating to the authenticity of the requesting representative.	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4	Mandatory	X.509 Policy 3.2.2, CA Browser Forum 3.2.2			
3.1.5.6	In all cases where the party named in a certificate generates its own keys that party shall be required to prove possession of	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the	Mandatory	X.509 Policy 3.2.1, CA Browser Forum 3.2.1			

COMP AUDIT REPORT

	the private key, which corresponds to the public key in the certificate request. For signature keys, this may be done by the entity using its private key to sign a value and providing that value to the issuing CA. The CA shall then validate the signature using the party's public key	requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4					

3.1.6. Guidelines for issuance of special purpose DSC

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.7. Guidelines for maintaining eKYC account by CA

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.8. General Guidelines to CAs

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.9. Identification and authentication for re key requests

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.10. Identification and authentication for revocation request

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Identification and authentication for revocation request							
3.1.10.1	In the case of loss of key, CA can suspend/revoke the certificate on verifying the subscriber's identity. In the case where subscriber is not in a position to communicate (death, unconscious state, mental disorder), on receiving such information CA can suspend the certificate and after verification the certificate can be revoked.	1. For sample revocation requests, verify the revocation requests are authenticated 2. Validate CA has a process implemented to suspend/revoke the certificate on verifying the subscriber's identity in case of loss of key	Mandatory	X.509 Policy 3.4, CA Browser Forum 3.4			

CCA - AUDIT REPORT

3.1.10.2	Revocation requests shall be authenticated. Requests to revoke a certificate may be authenticated using that certificate's associated public key, regardless of whether or not the private key has been compromised	1. For sample revocation requests, verify the revocation requests are authenticated 2. Validate CA has a process implemented to suspend/revoke the certificate on verifying the subscriber's identity in case of loss of key	Mandatory	X.509 Policy 3.4, , CA Browser Forum 3.4			

3.1.11. Initial identity validation

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.1.12. Naming

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Naming							
3.1.12.1	The CCA shall resolve any name collisions (other than subscribers) brought to its attention that may affect interoperability or trustworthiness	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.7, CA Browser Forum 3.1.7			
3.1.12.2	Name uniqueness of Root CA, licensed CA and SubCA shall be enforced	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous	Mandatory	X.509 Policy 3.1.5, CA Browser Forum 3.1.5			

COMPLIANCE AUDIT REPORT

		identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same					
3.1.12.3	CA and subscriber certificates shall not contain anonymous or pseudonymous identities.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.3, CA Browser Forum 3.1.3			
3.1.12.4	All DNs and associated directory information tree shall accurately reflect organizational structures.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.2, CA Browser Forum 3.1.2			
3.1.12.5	The certificates issued pursuant to CP are meaningful	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer	Mandatory	X.509 Policy 3.1.2, CA Browser Forum 3.1.2			

CCA - AUDIT REPORT

	only if the names that appear in the certificates can be understood and used by Relying Parties. Names used in the certificates must identify the person or object to which they are assigned in a meaningful way.	and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same					
3.1.12.6	The CAs shall generate and sign certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields. Subject Alternative Name may also be used, if marked non-critical.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.1, CA Browser Forum 3.1.1			
3.1.12.7	Rules for interpreting name forms shall be in accordance with applicable Standards	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA,	Mandatory	X.509 Policy 3.1.4, CA BrowserForum 3.1.4			

CCA - AUDIT REPORT

		licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same					

3.2. Certificate Management Controls

3.2.1. Certificate, crl and oscp profiles

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
OCSP Profiles							
3.2.1.1	OCSP requests and responses shall be in accordance with RFC 2560	1. Verify the OCSP requests and responses are in accordance with RFC 2560	Mandatory	X.504 Policy 7.3			
CRL Profile							
3.2.1.2	CA shall make a full and complete CRL available to the OCSP Responders	1. Check that the CA has made the full and complete CRL available to the OCSP responder	Mandatory	X.504 Policy 7.2.1			
Certificate profile							
3.2.1.3	extendedKeyUsage - This extension must NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
3.2.1.4	certificatePolicies - This extension should NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true	Mandatory	CA Browser Forum 7.1.2.2			

CCA AUDIT REPORT

		d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present					
3.2.1.5	keyUsage - This extension must be present and must be marked critical. Bit positions for keyCertSign and cRLSign must be set. If the Root CA Private Key is used for signing OCSP responses, then the digitalSignature bit must be set.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
3.2.1.6	basicConstraints - This extension must appear as a critical extension. The CA field must be set true. The pathLenConstraint field should NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
3.2.1.7	Certificates must be of type X.509 v3.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension	Mandatory	CA Browser Forum 7.1.1			

CC AUDIT REPORT

		c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present					
3.2.1.8	Effective September 30, 2016, CAs shall generate non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1			

3.2.2. Publication and repository responsibilities

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Access controls on repositories							
Publication of information							
3.2.2.1	The CA shall publicly give effect to these Requirements and represent that it will adhere to the latest published version. The CA may fulfill this requirement by incorporating these Requirements directly into its Certificate Policy and/or Certification Practice Statements or by incorporating them by reference using a clause such as the following (which must include a link to the official version of these Requirements): [Name of CA] conforms to	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Mandatory	CA Browser Forum 2.2			

CCA AUDIT REPORT

	the current version of the Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates published at http://www.cabforum.org. In the event of any inconsistency between this document and those Requirements, those Requirements take precedence over this document.						
3.2.2.2	Effective as of 31 May 2018, the Certificate Policy and/or Certification Practice Statement must be structured in accordance with RFC 3647. Prior to 31 May 2018, the Certificate Policy and/or Certification Practice Statement must be structured in accordance with either RFC 2527 or RFC 3647. The Certificate Policy and/or Certification Practice Statement must include all material required by RFC 3647 or, if structured as such, RFC 2527.	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Mandatory	CA Browser Forum 2.2			
3.2.2.3	The CA shall publicly disclose its Certificate Policy and/or Certification Practice Statement through an appropriate and readily accessible online means that is available on a 24x7 basis.	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Mandatory	CA Browser Forum 2.2			
3.2.2.4	The CA shall host test Web pages that allow Application Software Suppliers to test their software with Subscriber Certificates that chain up to each publicly trusted Root Certificate. At a minimum,	Check that the CA's repository is publically available in read only format	Mandatory	CA Browser Forum 2.3			

COM - AUDIT REPORT

	the CA shall host separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired						
Repositories							
3.2.2.5	The CA shall make revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy. The Certifying Authority shall ensure the continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties.	1. Verify the CA develops, implements, enforces, and annually updates a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements 2. Check the CA makes revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy 3. Validate CA ensures continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties	Mandatory	CA Browser Forum 2.1, IT Regulations 3			
3.2.2.6	The CA shall develop, implement, enforce, and annually update a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements	1. Verify the CA develops, implements, enforces, and annually updates a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements 2. Check the CA makes revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy 3. Validate CA ensures continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties	Mandatory	CA Browser Forum 2			

3.2.3. Subordinate CA Certificate and Cross Certificate Lifecycle Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Subordinate CA Certificate and Cross Certificate Lifecycle Management							
3.2.3.1	The Parent CA updates the Certificate Revocation List (CRL) and other Sub-CA or cross certificate status mechanisms upon	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.12			

CCA - AUDIT REPORT

	certificate revocation in accordance with the Parent CA's CP.						
3.2.3.2	The Parent CA verifies the identity and authority of the entity requesting revocation of a Sub-CA or cross certificate in accordance with the Parent CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.11			
3.2.3.3	The Parent CA makes Sub-CA and cross certificates available to relevant entities (e.g., Relying Parties) using an established mechanism (e.g., a repository such as a directory) in accordance with the Parent CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.10			
3.2.3.4	The Parent CA signs the Sub-CA or cross certificate with the Parent CA's private signing key	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.9			
3.2.3.5	The Parent CA generates certificates: • using the appropriate certificate profile in accordance with the CP and ISO 9594/X.509 and ISO 15782-1 formatting rules; • with the validity periods formatted in accordance with ISO 9594/X.509, ISO 15782-1 and the CP; and • where extensions are used, with extension fields formatted in accordance with ISO 9594/X.509,	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.8			

CCA - AUDIT REPORT

	ISO 15782-1 and the CP						
3.2.3.6	The Parent CA's CP specifies the requirements for submission of Sub-CA rekey requests	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.6			
3.2.3.7	Where Sub-CA certificate and cross certificate renewal is permitted, the Parent CA authenticates the Sub-CA or cross certificate renewal request in accordance with the CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.5			
3.2.3.8	Where Sub-CA and cross certificate renewal is permitted, the Parent CA's CP specifies the requirements for submission of Sub-CA or cross certificate renewal requests	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.4			
3.2.3.9	The Parent CA performs an assessment of the Sub-CA or cross certificate applicant's compliance with the requirements of the Parent CA's CP before approving a Sub-CA or cross certificate request, or alternatively the Sub-CA or cross certificate applicant presents its CPS for assessment.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.3			
3.2.3.10	The Parent CA authenticates the Sub-CA or cross certificate request in accordance with the Parent's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.2			

CCA - AUDIT REPORT

3.2.3.11	The Parent CP specifies the requirements for submission of Sub-CA and cross certification requests.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.1			
3.2.3.12	The Parent CA authenticates the Sub-CA certificate rekey request in accordance with the CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.7			

3.2.4. Certificate Lifecycle Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Certificate Status Services							
3.2.4.1	The CA shall maintain a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report, and where appropriate, forward such a complaint to law enforcement authorities, and/or revoke a Certificate that is the subject of such a complaint	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.2			
3.2.4.2	The CA shall maintain an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates issued by the CA.	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.2			
3.2.4.3	The CA shall operate and maintain its CRL	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP	Mandatory	CA Browser Forum 4.10.2			

COA - AUDIT REPORT

	and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating conditions.	Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report					
3.2.4.4	Revocation entries on a CRL or OCSP Response must NOT be removed until after the Expiry Date of the revoked Certificate	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.1			
Certificate Revocation and Suspension							
3.2.4.5	Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of	Mandatory	WebTrust 6.7.12			

CCSL AUDIT REPORT

		certificate suspensions are recorded in an audit log					
3.2.4.6	The CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log	Mandatory	WebTrust 6.7.11			
3.2.4.7	A certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted	Mandatory	WebTrust 6.7.9			

COR - AUDIT REPORT

		h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log					
3.2.4.8	Once a certificate suspension (hold) has been issued, the suspension is handled in one of the following three ways: • an entry for the suspended certificate remains on the CRL with no further action; • the CRL entry for the suspended certificate is replaced by a revocation entry for the same certificate; or • the suspended certificate is explicitly released and the entry removed from the CRL.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log	Mandatory	WebTrust 6.7.8			
3.2.4.9	The Certifying Authority shall publish a notice of suspension or revocation of any certificate in the Certificate Revocation List in its repository immediately after receiving an authorised request of such suspension or revocation. The CA records all certificate revocation requests and their outcome in an audit log.	1. Verify CA publishes a notice of suspension or revocation of any certificate in the Certificate Revocation List in its repository immediately after receiving an authorised request of such suspension or revocation. 2. Check all certification revocation requests and their outcome are logged	Mandatory	IT Regulation 3, WebTrust 6.6.6			
3.2.4.10	The CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms in the	1. Verify that the CA maintains and updates the Certificate Revocation List (CRL)	Mandatory	WebTrust 6.6.5			

CCA - AUDIT REPORT

	timeframes specified within the CP and in accordance with the format defined in ISO 9594/X.509 and ISO 15782-1.						
3.2.4.11	If an external RA accepts and forwards revocation requests to the CA, the CA provides a signed acknowledgement of the revocation request and confirmation of actions to the requesting RA.	1. Verify for past instances where the CA provides a signed acknowledgement of the revocation request and confirmation of action	Mandatory	WebTrust 6.6.4			
3.2.4.12	The CA verifies or requires that the RA verify the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP. The Subscriber, RA, or Issuing CA can initiate revocation. Additionally, Subscribers, Relying Parties, Application Software Suppliers, and other third parties may submit Certificate Problem Reports informing the issuing CA of reasonable cause to revoke the certificate	1. Validate that CA verifies the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP 2. Verify the Subscriber or Issuing CA can initiate revocation.	Mandatory	WebTrust 6.6.2, X.509 Policy 4.9.2, CA Browser Forum 4.9.2			
3.2.4.13	The CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the following: • one or more certificates of one or more subscribers; • the set of all certificates issued	1. Validate that CA verifies the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP 2. Verify the Subscriber or Issuing CA can initiate revocation.	Mandatory	WebTrust 6.6.1, X.509 Policy 4.9.3, CA Browser Forum 4.9.3			

CCA AUDIT REPORT

	by a CA based on a single public/private key pair used by a CA to generate certificates; and • all certificates issued by a CA, regardless of the public/private key pair used.The CA SHALL provide Subscribers, Relying Parties, Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. The CA SHALL publicly disclose the instructions through a readily accessible online means.						
3.2.4.14	The CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the following: • one or more certificates of one or more subscribers; • the set of all certificates issued by a CA based on a single public/private key pair used by a CA to generate certificates; and • all certificates issued by a CA, regardless of the public/private key pair used. The CA SHALL provide Subscribers, Relying Parties,	1. Check that the CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the elements mentioned in the control 2. Verify the CA provides Subscribers, Relying Parties, Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. 3. Validate the CA has publicly disclosed the instructions through a readily accessible online means	Mandatory	WebTrust 6.6.1, X.509 Policy 4.9.3, CA Browser Forum 4.9.3			

CCA - AUDIT REPORT

	Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. The CA SHALL publicly disclose the instructions through a readily accessible online means.						
3.2.4.15	A certificate shall be revoked when the binding between the subject and the subject's public key defined within a certificate is no longer considered valid. The CA SHALL provide a process for Subscribers to request revocation of their own Certificates. The process MUST be described in the CA's Certificate Policy or Certification Practice Statement. The CA SHALL maintain a continuous 24x7 ability to accept and respond to revocation requests and related inquiries	1. For sample cases, validate certificate is revoked when the binding between the subject and the subject's public key defined within a certificate is no longer considered valid 2. Verify the CA provides a process for Subscribers to request revocation of their own Certificates and the process is described in the CA's Certificate Policy or CCA-CAAC Ver 1.6 122 Certification Practice Statement. 3. Check the CA maintains a continuous 24x7 ability to accept and respond to revocation requests and related inquiries	Mandatory	X.509 Policy 4.9.1, CA Browser Forum 4.9			
Certificate Revocation List (CRL) Controls							
3.2.4.16	Old CRLs are retained for the appropriate period of time specified in the CA's CP.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's	Mandatory	WebTrust 6.8.9			

COPY AUDIT REPORT

		validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.					
3.2.4.17	The CRL contains entries for all revoked unexpired certificates issued by the CA.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.8			
3.2.4.18	CAs include a monotonically increasing sequence number for each CRL issued by that CA	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.7			
3.2.4.19	CRLs are archived in accordance with the requirements of the CP including the method of retrieval.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval	Mandatory	WebTrust 6.8.6			

CONFIDENTIAL AUDIT REPORT

		5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.					
3.2.4.20	If certificate suspension is supported, a certificate suspension (hold) entry, with its original action date and expiration date remain on the CRL until the normal expiration of the certificate or until the suspension is lifted	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.5			
3.2.4.21	At a minimum, a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.4			
3.2.4.22	The CA issues CRLs at regular intervals, as specified in the CP, even if no changes have occurred since the last issuance.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked	Mandatory	WebTrust 6.8.3			

COM - AUDIT REPORT

		unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.					
3.2.4.23	The CA digitally signs each CRL that it issues so that entities can validate the integrity of the CRL and the date and time of issuance.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.2			
Certificate Validation							
3.2.4.24	The CA makes certificate status information available to relevant entities (Relying Parties or their agents) using an established mechanism in accordance with the CP. This is achieved using: • Request Response Method – A request signed by the Relying Party to the Certificate Status Provider's responder. In turn, the Certificate Status Provider's responder responds with the certificate status duly signed. (OCSP is an example protocol using this method.) • Delivery Method – A CRL signed by the CA and published within the policy's time frame.	1. Check that the certificate status information is made available to relevant entities by the CA using an established mechanism in accordance with the CP 2. Verify Request Response Method and Delivery Method are used for Validation	Mandatory	WebTrust 6.8.1			
Certificate Re-Key							
3.2.4.25	A certificate re-key shall be achieved using one of the	1. Verify Certificate re-key is achieved using one of the following processes: a. Initial registration process	Mandatory	X.509 Policy 4.7.3, CA Browser Forum 4.7, X.509			

CCA - AUDIT REPORT

	following processes: • Initial registration process • Identification & Authentication for Re-key			Policy 4.7			
Certificate Renewal							
3.2.4.26	A certificate renewal shall be achieved using one of the following processes: • Initial registration process • Identification & Authentication for Re-key, except the old key can also be used as the new key	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6.3			
3.2.4.27	The CA makes the new certificate available to the end entity in accordance with the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.17			
3.2.4.28	The CA issues a signed notification indicating the certificate renewal has been successful.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.16			
3.2.4.29	The CA or RA notifies Subscribers prior to the expiration of their certificate of the need for renewal in accordance with the CP	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.15			
3.2.4.30	The CA checks the Certificate Renewal Request for errors or omissions. This function may be delegated explicitly to the RA	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.14			
3.2.4.31	The CA verifies the RA's signature on the Certificate Renewal Request	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.13			

CCA - AUDIT REPORT

3.2.4.32	The CA verifies the authenticity of the submission by the RA.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.12			
3.2.4.33	The CA requires that RAs record their actions in an audit log.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.11			
3.2.4.34	The CA requires that the RA secures that part of the certificate renewal process for which it (the RA) assumes responsibility in accordance with the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.10			
3.2.4.35	The CA requires that RAs submit the Certificate Renewal Data to the CA in a message (Certificate Renewal Request) signed by the RA.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.9			
3.2.4.36	The CA or the RA verifies that the request, including the extension of the validity period, meets the requirements defined in the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.8			
3.2.4.37	The CA verifies the existence and validity of the certificate The CA verifies the existence and validity of the certificate to be renewed. The CA does not renew certificates that have been revoked, expired or suspended to be renewed. The CA does not renew certificates that have been revoked, expired or suspended	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.7			

CCA - AUDIT REPORT

3.2.4.38	The CA or the RA validate the signature on the Certificate Renewal Request	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.6			
3.2.4.39	For domain validated certificates, the CA or the RA process the certificate renewal data to re-validate the domain in accordance with the requirements of the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.5			
3.2.4.40	For renewal of authenticated certificates, the CA or the RA process the certificate renewal data to verify the identity of the requesting entity and to identify the certificate to be renewed.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.4			
3.2.4.41	The CA issues a new certificate using the subscriber's previously certified public key, only if its cryptographic security is still sufficient for the new certificate's intended lifetime and no indications exist that the subscriber's private key has been compromised	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.3			
3.2.4.42	The CA requires that the requesting entity digitally sign the Certificate Renewal Request using the private key that relates to the public key contained in the requesting entity's existing public key certificate	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.2			
3.2.4.43	The Certificate	1. Certificate renewal is not performed as part	Not Applicable	WebTrust 6.2.1			

CCA - AUDIT REPORT

	Renewal Request includes at least the subscriber's Distinguished Name, the Serial Number of the certificate (or other information th0 at identifies the certificate), and the requested validity period. (The CA will only renew certificates that were issued by itself.)	of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.					
3.2.4.44	In addition, the validity period of the certificate must not exceed the remaining lifetime of the private key	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6			
3.2.4.45	A certificate may be renewed if the public key has not reached the end of its validity period, the associated private key has not been revoked or compromised, and the Subscriber name and attributes are unchanged.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6			
Key Pair and Certificate Usage							
3.2.4.46	Subscribers and CAs shall protect their private keys from access by any other party. Subscribers and CAs shall use their private keys for the purposes as constrained by the extensions (such as key usage, extended key usage, certificate policies, etc.) in the certificates issued to them	1. Check that the CAs protect their private keys from access by any other party. 2. Verify CAs use their private keys for the purposes as constrained by the extensions in the certificates issued to them	Mandatory	X.509 Policy 4.5.1, CA Browser Forum 4.5			
Certificate Acceptance							
3.2.4.47	Notification of certificate issuance by the CA to other entities	1. Verify procedures have been developed for certificate acceptance and publication and subject confirms acceptance of certificate 2. Verify CA notifies of certificate issuance	Mandatory	X.509 Policy 4.4, CA Browser Forum 4.4			

CCA - AUDIT REPORT

		to other entities					
3.2.4.48	Procedures shall be developed for certificate acceptance and publication of the certificate by the CA.The subject must confirm acceptance of the certificate upon notification of issuance bythe CA.	1. Verify procedures have been developed for certificate acceptance and publication and subject confirms acceptance of certificate 2. Verify CA notifies of certificate issuance to other entities	Mandatory	X.509 Policy 4.4, CA Browser Forum 4.4			
Certificate Distribution							
3.2.4.49	The integrity of the repository or alternative distribution mechanism is maintained and administered.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.4			
3.2.4.50	The performance of the CA's repository or alternative distribution mechanism is monitored and managed.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.3			
3.2.4.51	Only authorized CA personnel administer the CA's repository or alternative distribution mechanism.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.2			
Certificate Issuance							
3.2.4.52	Whether certificates expire, are revoked or are suspended, copies of certificates are retained for the	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile	Mandatory	WebTrust 6.4.10			

COPY AUDIT REPORT

	appropriate period of time specified in the CP.	b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.53	The CA issues an out-of-band notification to the Subscriber when a certificate is issued. Where this notification includes initial activation data, then control processes ensure safe delivery to the Subscriber.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued	Mandatory	WebTrust 6.4.9			

COA - AUDIT REPORT

		l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.54	The CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.8, X.509 Policy 4.3			
3.2.4.55	Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a	Mandatory	WebTrust 6.4.7			

COA - AUDIT REPORT

		certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.56	When an RA is used, the CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request. Certificate issuance by the Root CA SHALL require an individual authorized by the CA (i.e. the CA system operator, system officer, or PKI administrator) to deliberately issue a direct command in order for the Root CA to perform a certificate signing operation.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.6			
3.2.4.57	The CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key	Mandatory	WebTrust 6.4.5, CA Browser Forum 4.3			

COA - AUDIT REPORT

		f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.58	The CA signs the end entity's public key and other relevant information with the CA's private signing key.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.4			
3.2.4.59	Extension fields are formatted in accordance with ISO 9594/X.509 and ISO 15782-1 as	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate	Mandatory	WebTrust 6.4.3			

CCA - AUDIT REPORT

	disclosed within the CP.	Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.60	Validity periods are set in the CP and are formatted in accordance with ISO 9594/X.509 and ISO 15782-1 as disclosed within the CP.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to	Mandatory	WebTrust 6.4.2			

COA AUDIT REPORT

		the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.2.4.61	The CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile in accordance with ISO 9594/X.509 and ISO 15782-1 formatting rules as disclosed within the CP.CA shall verify the source of a certificate request before issuance.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.1,CA Browser Forum 4.3, X.509 Policy 4.3			
Subscriber Registration							
3.2.4.62	The CA verifies the authenticity of the submission by the RA in accordance with the CA's CPS.	1. Check that the authenticity of the submission by the RA is verified by the CA	Mandatory	WebTrust 6.1.17			
3.2.4.63	The CA requires that RAs record their actions in an audit log.	1. Verify all RA activities are recorded in an audit log	Mandatory	WebTrust 6.1.16			
3.2.4.64	The CA requires that the RA secure that part of the certificate application process for which it (the RA) assumes responsibility in	1. Verify that the RA secures that part of the certificate application process for which it assumes responsibility in accordance with the CA's CPS	Mandatory	WebTrust 6.1.15			

CCM AUDIT REPORT

	accordance with the CA's CPS.						
3.2.4.65	The CA requires that RAs submit the requesting entity's certificate request data to the CA in a message (Certificate Request) signed by the RA. The CA verifies the RA's signature on the Certificate Request.	1. Verify the RAs submit the requesting entity's certificate request data to the CA in a message (Certificate Request) signed by the RA	Mandatory	WebTrust 6.1.14			
3.2.4.66	The CA validates the identity of the RA authorized to issue registration requests under a specific CP.	1. Verify requesting entity submits its public key in a self-signed message to the CA for certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA	Mandatory	WebTrust 6.1.13			
3.2.4.67	The certificate request is treated as acceptance of the terms of conditions by the requesting entity to use that certificate as described in the Subscriber Agreement	1. Verify requesting entity submits its public key in a self-signed message to the CA for certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA	Mandatory	WebTrust 6.1.12			
3.2.4.68	The CA requires that the requesting entity submit its public key in a self-signed message to the CA for certification. The CA requires that the requesting entity digitally sign the Registration Request using the private key that relates to the public key contained in the Registration Request in order to: • allow the	1. Verify requesting entity submits its public key in a self-signed message to the CA for certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA	Mandatory	WebTrust 6.1.11			

CCA AUDIT REPORT

	detection of errors in the certificate application process; and • Prove possession of the companion private key for the public key being registered.						
3.2.4.69	The CA requires that an entity requesting a certificate must prepare and submit the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	1. Conduct walkthrough and check the following: a. Before certificate issuance the CA informs the Subscriber of the terms and conditions regarduse of the certificate. b. The entity requesting a certificate prepares and submits the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	Mandatory	WebTrust 6.1.10			
3.2.4.70	At the point of registration (before certificate issuance) the RA or CA informs the Subscriber of the terms and conditions regarding use of the certificate.	1. Conduct walkthrough and check the following: a. Before certificate issuance the CA informs the Subscriber of the terms and conditions regarduse of the certificate. b. The entity requesting a certificate prepares and submits the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	Mandatory	WebTrust 6.1.8			
3.2.4.71	Encryption and access controls are used to protect the confidentiality and integrity of registration data in transit and in storage.	1. Verify encryption and access controls are used to protect the confidentiality and integrity of registration data in transit and in storage.	Mandatory	WebTrust 6.1.7			
3.2.4.72	The CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP	Mandatory	WebTrust 6.1.6			

COA - AUDIT REPORT

		d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.2.4.73	For end entity certificates, the CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.5			
3.2.4.74	The CA or RA checks the Certificate Request for errors or omissions in accordance with the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the	Mandatory	WebTrust 6.1.4			

COA - AUDIT REPORT

		requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.2.4.75	The CA or RA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.3			
3.2.4.76	For domain and/or IP address validated certificates, the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates	Mandatory	WebTrust 6.1.2			

CCA - AUDIT REPORT

		c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.2.4.77	For authenticated certificates, the CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.1			

3.3. Key Management Controls

3.3.1. Subscriber Key Lifecycle Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Confidentiality of Subscriber's Information							
3.3.1.1	A secure communication channel between the Certifying	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data	Mandatory	IT CA Rules SCHEDULE III 22			

COA AUDIT REPORT

	Authority and its subscribers shall be established to ensure the authenticity, integrity and confidentiality of the exchanges (e.g. transmission of Digital Signature Certificate, password, private key) during the Digital Signature Certificate issuance process.	2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange					
3.3.1.2	Data on the usage of the Digital Signature Certificates by the subscribers and other transactional data relating to the subscribers' activities generated by the Certifying Authority in the course of its operation shall be protected to ensure the subscribers' privacy	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data 2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange	Mandatory	IT CA Rules SCHEDULE III 22			
3.3.1.3	Procedures and security controls to protect the privacy and confidentiality of the subscribers' data under the Certifying Authority's custody shall be implemented. Confidential nformation provided by the subscriber must not be disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order.	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data 2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange	Mandatory	IT CA Rules SCHEDULE III 22			
Certificate Operational Periods and Key Pair Usage Periods							

CCA - AUDIT REPORT

3.3.1.4	Subscriber SSL Certificates issued after 1 March 2018 must have a Validity Period no greater than 825 days. Subscriber Certificates issued after 1 July 2016 but prior to 1 March 2018 must have a Validity Period no greater than 39 months.	1. For sample SSL certificates issued after 1 March 2018, verify the validity period is not greater than 825 days 2. For sample certificates issued after 1 July 2016 but prior to 1 March 2018, verify the validity period is not greater than 39 months	Applicable for SSL Certificate	CA Browser Forum 6.3.2			
Requirements for Subscriber Key Management							
3.3.1.5	The CP specifies the requirements for notification of the CA or RA in the event of subscriber key compromise.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication	Mandatory	WebTrust 5.4.16			

COPY AUDIT REPORT

		processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.6	CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes (and subsequent actions) where the cryptographic hardware is in other physical locations (i.e., an HSM attached to a mainframe or remote server).	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.15			
3.3.1.7	The CP or CPS specifies the requirements for destruction of all	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following:	Mandatory	WebTrust 5.4.14			

CCA - AUDIT REPORT

	copies and fragments of the subscriber's private key at the end of the key pair life cycle.	a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.8	The CP specifies the means through which subscriber key destruction is performed.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key	Mandatory	WebTrust 5.4.13			

COPY AUDIT REPORT

		protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.9	The CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the	Mandatory	WebTrust 5.4.12			

COPY AUDIT REPORT

		required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.10	The CP specifies the private key protection requirements for archived subscriber private keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for	Mandatory	WebTrust 5.4.11			

COPY AUDIT REPORT

		destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.11	The CP specifies the requirements for subscriber key usage.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for	Mandatory	WebTrust 5.4.10			

COPY AUDIT REPORT

		use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.12	The CP specifies the acceptable uses for subscriber key pairs.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.9			
3.3.1.13	Subscriber Agreements	1. Conduct walkthrough of the CA-Provided Subscriber Key	Mandatory	Subscriber Agreements describe the required processes to be			

CCA AUDIT REPORT

	describe the required processes to be followed by the Subscriber of any use of the cryptographic mechanism (e.g., HSM or ICC and software application).	Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.14	The CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key	Mandatory	WebTrust 5.4.7			

COPY AUDIT REPORT

		sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.15	The CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys	Mandatory	WebTrust 5.4.6			

CONFIDENTIAL AUDIT REPORT

		stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.16	The CP specifies the private key protection requirements for stored subscriber private keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber	Mandatory	WebTrust 5.4.5			

COPY AUDIT REPORT

		private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.17	The CA or RA provides or makes available the mechanisms to allow the Subscriber to access (i.e., private key owner verification method), manage and control the usage of their private keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of	Not Applicable	WebTrust 5.4.4			

COPY AUDIT REPORT

		the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.3.1.18	The CP specifies the acceptable key sizes for subscriber key generation.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.3			

CCA - AUDIT REPORT

3.3.1.19	The CP specifies the key generation algorithm(s) that is used for subscriber key generation.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.2			
3.3.1.20	The CP specifies the appropriate ISO 15782-1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber	Mandatory	WebTrust 5.4.1			

COPY AUDIT REPORT

		key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
CA-Provided Subscriber Key Storage and Recovery Services							
3.3.1.21	If the CA (or RA) provides subscriber key storage, backup and recovery, controls exist to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca	Mandatory	WebTrust 5.2.5			

COPY - AUDIT REPORT

		generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.3.1.22	If the CA (or RA) provides subscriber (confidentiality) key storage, backup and recovery, subscriber private (confidentiality) key backup and recovery services are only performed by authorized personnel.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	WebTrust 5.2.4			
3.3.1.23	If the CA (or RA) generates public/private signing key pair(s), it does not maintain a copy of any private signing key, once the subscriber confirms receipt of that key.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form	Mandatory	WebTrust 5.2.3			

COA - AUDIT REPORT

		using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.3.1.24	If the CA generates key pair(s) on behalf of a Subscriber, the CA (or RA) ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	WebTrust 5.2.2			
3.3.1.25	Subscriber private keys stored by the CA (or RA) are stored in encrypted form using a cryptographic algorithm and key	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation	Mandatory	WebTrust 5.2.1			

CCA - AUDIT REPORT

	length based on a risk assessment and requirements of the CP.	code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.3.1.26	The Certifying Authority's key custodians shall ensure that the Certifying Authority's key component or the activation code is always under his sole custody. Change of key custodians shall be approved by the Certifying Authority's management and documented	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	IT CA Rules SCHEDULE III 18.3documented			
3.3.1.27	Certifying Authority's keys	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and	Mandatory	IT CA Rules SCHEDULE III 18.3			

CCA AUDIT REPORT

	shall be stored in tamper-resistant devices and can only be activated under split-control by parties who are not involved in the set-up and maintenance of the systems and operations of the Certifying Authority. The key of the Certifying Authority may be stored in a tamper-resistant cryptographic module or split into sub-keys stored in tamper-resistant devices under the custody of the key custodians	Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
CA-Provided Subscriber Key Generation Services							
3.3.1.28	When subscriber key generation is performed by the CA (or RA or card bureau), the CA (or RA or card bureau) securely (confidentially) delivers the subscriber key pair(s) generated by the CA (or RA or card bureau) to the subscriber in accordance with the CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.6			
3.3.1.29	Subscriber key generation performed by the CA (or RA) is performed by authorized personnel in accordance with the CA's CPS.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.5			
3.3.1.30	Subscriber key	1. No action is required from the	Not Applicable	WebTrust 5.1.4			

CCA - AUDIT REPORT

	generation performed by the CA (or RA or card bureau) results in key sizes in accordance with the CP.	auditor to check the controls as Subscriber key generations services are not provided by CAs					
3.3.1.31	Subscriber key generation performed by the CA (or RA) uses a prime number generator as specified in an ANSI X9 or ISO standard	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.3			
3.3.1.32	Subscriber key generation performed by the CA (or RA or card bureau) uses a key generation algorithm as specified in the CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.2			
3.3.1.33	Subscriber key generation is performed within a secure cryptographic device meeting the applicable ISO 15782-1/FIPS140-2/ANSI x9.66 requirements based on a risk assessment and the business requirements of the CA and in accordance with the applicable CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.1, CA Browser Forum 6.1.1.3			
3.3.1.34	The Certifying Authority's public verification key must be delivered to the prospective Digital Signature Certificate holder in an on-line transaction in accordance with PKIX-3 Certificate Management Protocol, or via an equally secure manner. The	1. Conduct walkthrough and check the following: a. CAs public verification key is delivered to the prospective Digital Signature Certificate holder in an on-line transaction in accordance with PKIX-3 Certificate Management Protocol, or via an equally secure manner. b. Certifying Authority ensures that the subscriber can verify the Certifying Authority's Public Key Certificate, if he chooses to do so, by having access to the Public Key Certificate of the Controller	Optional				

COMPLIANCE AUDIT REPORT

	Certifying Authority shall ensure that the subscriber can verify the Certifying Authority's Public Key Certificate, if he chooses to do so, by having access to the Public Key Certificate of the Controller						

3.3.2. Key Lifecycle Management Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Private Key Protection and Cryptographic Module Engineering Controls							
3.3.2.1	The cryptographic module may store Private Keys in any form as long as the keys are not accessible without authentication mechanism that is in compliance with FIPS 140-2 rating of the cryptographic module.	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Recommended	X.509 Policy 6.2.7			
3.3.2.2	Use of a CA private signing key shall require action by at least two persons	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Mandatory	X.509 Policy 6.2.2			
3.3.2.3	The Certifying	1. Conduct walkthrough of Private	Mandatory	IT CA Rules SCHEDULE			

CCA AUDIT REPORT

	Authority's private key backups should be stored in a secure storage facility, away from where the original key is stored. Continued availability of the private key be ensured through approved backup measures in the event of loss or corruption of its private key.	Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party		III 19, IT Regulations 3			
3.3.2.4	The Certifying Authority must protect its private keys from disclosure. The Certifying Authority must back-up its private keys. Backed-up keys must be stored in encrypted form and protected at a level no lower than those followed for storing the primary version of the key.	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Mandatory	IT CA Rules SCHEDULE III 19			
Key Migration							
3.3.2.5	Upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed in accordance with the CA’s disclosed business practices	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed	Mandatory	WebTrust 4.11.7			
3.3.2.6	CA key migration events shall be witnessed by internal or external auditors	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no	Mandatory	WebTrust 4.11.6			

CCA AUDIT REPORT

		longer serve a business purpose shall be securely destroyed					
3.3.2.7	A log is maintained of all actions taken as part of the CA key migration event and is retained in accordance with the CA's disclosed business practices.	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed	Mandatory	WebTrust 4.11.5			
3.3.2.8	The CA follows a CA key migration script for key migration events that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key migration event • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be migrated and new hardware where the keys are being migrated to; • specific steps performed during the key migration ceremony, including; • Hardware preparation o Software tool installation and setup o Cryptographic hardware setup and initialization o CA key migration o CA key verification • physical security requirements for the event location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the migration event • sign-off on the script or in a log from participants and witnesses indicating	1. Obtain a copy of the CA key migration script and check the following: a. Script covers roles assigned, management approval,serial numbers, procedures for secure storage of cryptographic hardware etc. b. Steps for performing key migration are stated clearly in the script c. physical security requirements for the ceremony location are met d. sign-off is given for the key migration ceremony e. notation of any deviations from the key generation ceremony script are addressed	Mandatory	WebTrust 4.11.4			

CCA - AUDIT REPORT

	whether the key migration was performed in accordance with the detailed key migration script; and • notation of any deviations from the key migration script (e.g., documentation of steps taken to address any technical issues).						
3.3.2.9	In-house developed software tools are developed and tested by the CA prior to the key migration event in accordance with its standard software development process	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.3			
3.3.2.10	Vendor-supplied hardware and software tools are tested by the CA prior the key migration event, and are operated in accordance with vendor-supplied documentation and instructions.	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.2			
3.3.2.11	CA key migration events occur in a physically secure environment by those in Trusted Roles under multi-person control	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.1			
3.3.2.12	The CA follows a CA key migration script for key migration events that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key migration event • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be	1. Obtain a copy of the CA key migration script and check the following: a. Script covers roles assigned, management approval,serial numbers, procedures for secure storage of cryptographic hardware etc. b. Steps for performing key migration are stated clearly in the script c. physical security requirements for the ceremony location are met d. sign-off is given for the key migration ceremony e. notation of any deviations from the key generation ceremony script are addressed	Mandatory	WebTrust 4.11.4			

CCA AUDIT REPORT

	migrated and new hardware where the keys are being migrated to; • specific steps performed during the key migration ceremony, including; • Hardware preparation o Software tool installation and setup o Cryptographic hardware setup and initialization o CA key migration o CA key verification • physical security requirements for the event location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the migration event • sign-off on the script or in a log from participants and witnesses indicating whether the key migration was performed in accordance with the detailed key migration script; and • notation of any deviations from the key migration script (e.g., documentation of steps taken to address any technical issues).						
Key Changeover							
3.3.2.13	To minimize risk from compromise of a CA's private signing key, that key may be changed often; from that time on, only the new key shall be used for certificate signing purposes. The older, but still valid, certificate will be available to verify old signatures until all of the certificates signed using the associated private key have also expired. If the old private key is used to sign CRLs, then the old key shall be retained and protected.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	X.509 Policy			

CCA AUDIT REPORT

3.3.2.14	All CA keys must have validity periods of no more than ten years.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1			
3.3.2.15	The Certifying Authority shall define its key change process that ensures reliability of the process by showing how the generation of key interlocks – such as signing a hash of the new key with the old key.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1			
3.3.2.16	The Certifying Authority shall provide reasonable notice to the Subscriber's relying parties of any change to a new key pair used by the Certifying Authority to sign Digital Signature Certificates.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1			
3.3.2.17	Certifying Authority and Subscriber keys shall be changed periodically. Key change shall be processed as per Key Generation guidelines.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA	Mandatory	IT CA Rules SCHEDULE III 21.1, X.509 Policy 5.6, CA Browser			

CCA AUDIT REPORT

		d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise					
Key Transportation							
3.3.2.18	Internal or external auditors accompany CA personnel during CA key transportation events.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.11			
3.3.2.19	A log is maintained of all actions taken as part of the CA key transportation event and is retained in accordance with the CA's disclosed business practices.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their	Mandatory	WebTrust 4.10.10			

CC AUDIT REPORT

		responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.20	Personnel involved in a CA key transportation event are in Trusted Roles and have received training in their role and responsibilities.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt	Mandatory	WebTrust 4.10.9			

CCA AUDIT REPORT

		i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.21	Upon receipt at the destination, CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.8			
3.3.2.22	Upon receipt at the destination, packaging for CA keys and activation materials are reviewed for evidence of tampering. If evidence of tampering is discovered, the Policy Authority is notified of a	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for	Mandatory	WebTrust 4.10.7			

CCA AUDIT REPORT

	possible breach event	Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.23	Activation materials are transported separately from the CA key (i.e. by a different method and/or at a different time) in tamper-evident packaging	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and	Mandatory	WebTrust 4.10.6			

CCA AUDIT REPORT

		activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.24	If the CA key is divided into fragments on multiple hardware devices: • If transported by CA employees, each fragment is transported separately using different transportation routes, methods, and/or times; or • If transported by common carrier, each fragment is sent using a different common carrier at different times. Shipments require signature service, tracking, are insured.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.5			
3.3.2.25	If the hardware device contains the entire CA key, it is physically transported by at least two CA employees and remains under multi-person control from	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person	Mandatory	WebTrust 4.10.4			

CCA - AUDIT REPORT

	origin to destination.	control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.26	CA keys are only transported on hardware devices and in tamper-evident packaging as disclosed in the CA's business practices.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA	Mandatory	WebTrust 4.10.3			

CCA AUDIT REPORT

		key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.27	CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.2			
3.3.2.28	CA keys are prepared for transport in a physically secure environment by personnel in Trusted	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by	Mandatory	WebTrust 4.10.1			

CCA - AUDIT REPORT

	Roles and under multi-person control	personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
Key Escrow							
3.3.2.29	If CA private signing keys are held in escrow, escrowed copies of the CA private signing keys have the same or greater level of security controls as keys currently in use.	1. Verify if third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties 2. Validate if CA private keys are held in escrow, escrowed copies of CA private signing keys have the same or greater level of se urity controls as keys currently in use	Mandatory	WebTrust 4.9.2			
3.3.2.30	If a third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties.	1. Verify if third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties 2. Validate if CA private keys are held in escrow, escrowed copies of CA private signing keys have the same or greater level of se urity controls as keys currently in use	Mandatory	WebTrust 4.9.1			
Cryptographic Hardware Life Cycle Management							

CA AUDIT REPORT

3.3.2.31	Devices used for private key storage and recovery and the interfaces to these devices are tested before usage for integrity.	1. Verify by checking reports of the testing performed on devices used 1for private key storage	Mandatory	WebTrust 4.8.6			
3.3.2.32	The handling of CA cryptographic hardware, including the following tasks, is performed in the presence of no less than two trusted employees: • installation of CA cryptographic hardware; • removal of CA cryptographic hardware from production; • servicing or repair of CA cryptographic hardware (including installation of new hardware, firmware, or software); and • disassembly and permanent removal from use	1. Obtain names of employees responsible for handling of CA cryptographic hardware 2. Validate by discussing with them if they were present during installation, removal servicing, repair, disassembly and permanent removal of CA cryptographic hardware	Mandatory	WebTrust 4.8.5			
3.3.2.33	When not attached to the CA system, the CA cryptographic hardware is stored in a tamper resistant container that is stored securely under multiple controls (i.e., a safe)	1. Validate use of tamper resistant containers to store the CA cryptographic hardware	Mandatory	WebTrust 4.8.4			
3.3.2.34	Upon the receipt of CA cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed. Upon the receipt of CA cryptographic hardware that has been serviced or repaired, acceptance testing and verification of firmware settings is performed.	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description	Mandatory	WebTrust 4.8.2			
3.3.2.35	CA cryptographic hardware which does not contain CA keys is sent from the manufacturer or	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or	Mandatory	WebTrust 4.8.1			

CCF AUDIT REPORT

	alternate CA site via registered mail (or equivalent) using tamper evident packaging. Upon the receipt of CA cryptographic hardware from the manufacturer or alternate site, authorized CA personnel inspects the tamper evident packaging to determine whether the seal is intact.	alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description					
3.3.2.36	Diagnostic support is provided during troubleshooting of CA cryptographic hardware in the presence of no less than two trusted employees	1. Validate diagnostic support is provided and check the names of trusted employees responsible for overlooking support	Mandatory	WebTrust 4.8.8			
3.3.2.37	Correct processing of CA cryptographic hardware is verified on a periodic basis.	1. Validate the processing of cryptographic hardware is verified on a periodic basis.	Mandatory	WebTrust 4.8.7			
3.3.2.38	To prevent tampering, CA cryptographic hardware is stored and used in a secure site, with access limited to authorized personnel, having the following characteristics: • inventory control processes and procedures to manage the origination, arrival, condition, departure and destination of each device; • access control processes and procedures to limit physical access to authorized personnel; • recording of all successful or failed access attempts to the CA facility and device storage mechanism (e.g., a safe) in audit logs; • incident handling processes and procedures to handle abnormal events, security breaches, and investigation and reports; and • monitoring processes and procedures to verify	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description	Mandatory	WebTrust 4.8.3			

CCA - AUDIT REPORT

	the ongoing effectiveness of the controls.						
Key Compromise							
3.3.2.39	The CA's business continuity plan for key compromise addresses who is notified and what actions are taken with system software and hardware, symmetric and asymmetric keys, previously generated signatures and encrypted data.	1. Verify CA's business continuity plan addresses list of people to be notified and what actions are taken with system software and hardware, symmetric and asymmetric keys, previously generated signatures and encrypted data	Mandatory	WebTrust 4.7.5			
3.3.2.40	In the event that the CA has to replace its Root CA private key, procedures are in place for the secure and authenticated revocation of the following: • the old CA root public key; • the set of all certificates (including any self-signed) issued by a Root CA or any CA based on the compromised private key; and • any subordinate CA public keys and corresponding certificates that require recertification	1. Validate CA has a procedure in place in the event that the CA has to replace its private key	Mandatory	WebTrust 4.7.4			
3.3.2.41	The recovery procedures used if the CA's private key is compromised include the following actions: • how secure key usage in the environment is re-established; • how the CA's old public key is revoked; • how affected parties are notified (e.g., impacted CAs, Repositories, Subscribers and CVSPs); • how the CA's new public key is provided to the end entities and Relying Parties together with the mechanism for their authentication; and • how the subscriber's public keys are re-	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise 3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47	Mandatory	WebTrust 4.7.3			

CCA AUDIT REPORT

	certified.						
3.3.2.42	Disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise of a CA's private signing key.	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise 3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47	Mandatory	WebTrust 4.7.2			
3.3.2.43	The CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster.	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise 3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47	Mandatory	WebTrust 4.7.1			
3.3.2.44	Archives of Certifying Authority's public keys shall be protected from unauthorized modification	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3			
3.3.2.45	The Certifying Authority's public keys shall be archived permanently to facilitate audit or investigation requirements	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are	Mandatory	IT CA Rules SCHEDULE III 21.3			

CCA AUDIT REPORT

		protected from unauthorized modification					
3.3.2.46	The Certifying Authority should immediately revoke the affected keys and Digital Signature Certificates in the case of Subscriber private key compromise.	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3, IT Regulations 3			
3.3.2.47	A procedure shall be pre-established to handle cases where a compromise of the Certifying Authority's Digital Signature private key has occurred.	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3, IT Regulations 3, X.509 Polic			
Key Destruction							
3.3.2.48	CA key destruction ceremonies are independently witnessed by internal or external auditors.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could	Mandatory	WebTrust 4.6.9			

CCA AUDIT REPORT

		be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.49	The CA follows a CA key destruction script for key destruction ceremonies that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key destruction ceremony; • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be destroyed; • specific steps performed during the key destruction ceremony, including; o HSM and/or cryptographic hardware zeroisation/initialisation o HSM and/or cryptographic hardware physical destruction o Deletion of any encrypted files containing the CA key or fragments thereof • physical security requirements for the ceremony location(e.g.,	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case	Mandatory	WebTrust 4.6.8			

CCA AUDIT REPORT

	barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the key destruction ceremony pending their disposal or additional destruction • sign-off on the script or in a log from participants and witnesses indicating whether the key destruction ceremony was performed in accordance with the detailed key destruction ceremony script; and • notation of any deviations from the key destruction ceremony script (e.g., documentation of steps taken to address any technical issues).	is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.50	Backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently	Mandatory	WebTrust 4.6.7			

CONFIDENTIAL AUDIT REPORT

		removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.51	If a CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39	Mandatory	WebTrust 4.6.6			

CC AUDIT REPORT

		7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.52	If a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.6.5			
3.3.2.53	If a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely	Mandatory	WebTrust 4.6.4			

CCA - AUDIT REPORT

	have ever been or potentially could be used for any cryptographic purpose are destroyed.	destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.54	All copies and fragments of the CA's private key are destroyed at the end of the key pair life cycle in a manner such that the private key cannot be retrieved.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible	Mandatory	WebTrust 4.6.3			

CONFIDENTIAL AUDIT REPORT

		and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.55	Authorization to destroy a CA private key and how the CA's private key is destroyed (e.g., token surrender, token destruction, or key overwrite) are limited in accordance with the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic	Mandatory	WebTrust 4.6.2			

CC AUDIT REPORT

		device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.56	The CA's private keys shall be destroyed only if the business purpose or application has ceased to have value or legal obligations have expired as disclosed within the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction	Mandatory	WebTrust 4.6.1			

CONFIDENTIAL AUDIT REPORT

		ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.3.2.57	The CA's private keys shall be destroyed only if the business purpose or application has ceased to have value or legal obligations have expired as disclosed within the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.6.1			
3.3.2.58	Upon termination of use of a private key, all copies of the private key in computer memory	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a	Mandatory	IT CA Rules SCHEDULE III 20			

CCA - AUDIT REPORT

	and shared disk space must be securely destroyed by over-writing. Private key destruction procedures must be described in the Certification Practice Statement or other publicly available document.	private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
Key Archival							
3.3.2.59	Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for	Mandatory	WebTrust 4.5.5			

CONFIDENTIAL REPORT

		the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period					
3.3.2.60	Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.4			
3.3.2.61	Archived keys are only accessed where historical evidence requires validation. Control processes are required to ensure the integrity of the CA systems and the key sets.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.3			
3.3.2.62	All archived CA keys are destroyed at the end of the archive period using dual control in a physically secure site. Subscriber private signature keys shall not be archived by the CA	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is	Mandatory	WebTrust 4.5.2, X.509 Policy 6.2.5			

CCA AUDIT REPORT

		not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period					
3.3.2.63	Archived CA keys are subject to the same or greater level of security controls as keys currently in use.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.1 CA Browser Forum 6.3.1, X.509 Policy 6.3.1			
Key Usage							
3.3.2.64	Private Keys corresponding to Root Certificates MUST NOT be used to sign Certificates except in the following cases: • Self-signed Certificates to represent the Root CA itself; • Certificates for Subordinate CAs and Cross Certificates; • Certificates for infrastructure purposes (administrative role certificates, internal CA operational device certificates); and • Certificates for OCSP Response verification	1. Verify the private keys corresponding to Root Certificate are not used to sign Certificates except in the cases mentioned in control description	Mandatory	CA Browser Forum 6.1.7, X.509 Policy 6.1.7			
3.3.2.65	An annual review is required by the PA on key lengths to determine the appropriate key usage period with	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading	Mandatory	WebTrust 4.4.5			

COMP - AUDIT REPORT

	recommendations acted upon.	b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime					
3.3.2.66	In the event of a compromise of the private key the Certifying Authority shall follow the established procedures for immediate revocation of the affected subscribers' certificates. The CA ceases to use a key pair at the end of the key pair's defined operational lifetime or when the compromise of the private key is known or suspected	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime	Mandatory	IT Regulations 3, WebTrust 4.4.4			
3.3.2.67	CA signing key(s) used for generating certificates and/or issuing revocation status information, shall not be used for any other purpose.	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication	Mandatory	WebTrust 4.4.3			

CCA AUDIT REPORT

		e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime					
3.3.2.68	The activation of the CA private key shall be performed using multi-factor authentication (e.g., smart card and password, biometric and password, etc.).	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime	Mandatory	WebTrust 4.4.2			
3.3.2.69	The activation of the CA private signing key shall be performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs).	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the	Mandatory	WebTrust 4.4.1			

CCAK AUDIT REPORT

		end of the key pair’s defined operational lifetime					
3.3.2.70	A system and software integrity check shall be performed prior to Certifying Authority's key loading. Custody of and access to the Certifying Authority's keys shall be under split control. In particular, Certifying Authority's key loading shall be performed under split control	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA’s keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers’ certificates. g. CA ceases to use a key pair at the end of the key pair’s defined operational lifetime	Mandatory	IT CA Rules SCHEDULE III 18.4			
Key Distribution							
3.3.2.71	The CA provides a mechanism for validating the authenticity and integrity of the CA’s public keys.The CA provides a mechanism for validating the authenticity and integrity of the CA’s public keys.	1. Verify CA has a mechanism in place for validating the authenticity and integrity of the CA’s public keys	Mandatory	WebTrust 4.3.6			
3.3.2.72	If an entity already has an authenticated copy of the CA’s public key, a new CA public key is distributed using one of the following methods: • direct electronic transmission from the CA; • placing into a remote cache or directory; • loading into a cryptographic module; or • any of the methods used for initial distribution	1. Validate on a sample basis if an entity has an authenticated copy of CAs public key, a new CA public key is distributed using one of the methods mentioned in control description	Mandatory	WebTrust 4.3.5			

CCA - AUDIT REPORT

3.3.2.73	The subsequent distribution mechanism for the CA's public key is controlled in accordance with the CA's disclosed business practices.	1. On a sample basis verify the distribution mechanism for the CA's public key is controlled in accordance with the CA's disclosed business practices	Mandatory	WebTrust 4.3.4			
3.3.2.74	The CA's public key is changed (rekeyed) periodically according to the requirements of the CPS with advance notice provided to avoid disruption of the CA services	1. Verify by checking documentation of frequency of change of public key and validate CA's public key is changed (rekeyed) periodically according to the requirements	Mandatory	WebTrust 4.3.3			
3.3.2.75	The initial distribution mechanism for the CA's public key is controlled and initially distributed within a Certificate using one of the following methods: • machine readable media (e.g., smart card, flash drive, CD ROM) from an authenticated source; • embedding in an entity's cryptographic module; or • other secure means that ensure authenticity and integrity.	1. Validate the initial distribution mechanism for the CA's public key is controlled and initially distributed within a Certificate using one of the methods mentioned in control description	Mandatory	WebTrust 4.3.2			
3.3.2.76	Keys shall be transferred from the key generation system to the storage device (if the keys are not stored on the key generation system) using a secure mechanism that ensures confidentiality and integrity	1. Verify the key is transferred from the key generation system to the storage device using a secure mechanism that ensures confidentiality and integrity	Mandatory	IT CA Rules SCHEDULE III 18.2			
Key Storage, Backup, and Recovery							
3.3.2.77	Backup copies of the CA's private keys are subject to the same or greater level of security controls as keys currently in use. The recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private	Mandatory	WebTrust 4.2.4			

CCA AUDIT REPORT

		keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.					
3.3.2.78	If the CA's private keys are exported from a secure cryptographic module to secure storage for purposes of offline processing or backup and recovery, then they are exported within a secure key management scheme that may include any of the following: • as cipher-text using a key which is appropriately secured; • as encrypted key fragments using multiple control and split knowledge/ownership; or • In another secure cryptographic module such as a key transportation device using multiple control.	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.	Mandatory	WebTrust 4.2.3			
3.3.2.79	If the CA's private keys are not exported from a secure cryptographic module, then the CA private key is generated, stored and used within the same cryptographic module.	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control	Mandatory	WebTrust 4.2.2			

CC AUDIT REPORT

		3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.					
3.3.2.80	The CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or FIPS 140-1 level 3 recommendations for Cryptographic Modules Validation Listbased on a risk assessment and the business requirements of the CA and in accordance with the CA's CPS and applicable Certificate Policy(s)	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.	Mandatory	WebTrust 4.2.1, IT Regulations 3, CA Browser Forum 6.2.7, X.		
Key Generation							
3.3.2.81	The integrity of the hardware/software used for key generation and the interfaces to the hardware/software is tested before production usage.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used	Mandatory	WebTrust 4.1.6		

CONFIDENTIAL AUDIT REPORT

		f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					
3.3.2.82	The CA follows a CA key generation script for key generation ceremonies that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key generation ceremony; • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers; • specific steps performed during the key generation ceremony • physical security requirements for the ceremony location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and activation materials following the key generation ceremony (e.g., detailing the allocation of materials between storage locations); • sign-off on the script or in a log from participants and witnesses indicating whether key generation ceremony was performed in accordance with the detailed key generation ceremony script; and • notation of any deviations from the key generation ceremony script (e.g., documentation of steps taken to address any technical issues)	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.5		

CCA - AUDIT REPORT

3.3.2.83	CA key generation ceremonies are independently witnessed by internal or external auditors. The private key of the Certifying Authority shall be adequately secured at each phase of its life cycle, i.e. key generation, distribution, storage, usage, backup, archival and destruction.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.4, IT Regulations 3			
3.3.2.84	CA key generation generates keys that: • use a key generation algorithm as disclosed within the CA's CP and/or CPS; • have a key length that is appropriate for the algorithm and for the validity period of the CA certificate as disclosed in the CA's CP and/or CPS. The public key length to be certified by a CA is less than or equal to that of the CA's private signing key; and • take into account requirements on parent and subordinate CA key sizes and have a key size in accordance with the CA's CP and/or CPS.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle	Mandatory	WebTrust 4.1.3			

CCA - AUDIT REPORT

		2. Verify the steps by referring a recent key generation activity					
3.3.2.85	The CA shall generate its own key pair in the same cryptographic device in which it will be used or the key pair shall be injected directly from the device where it was generated into the device where it will be used.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.2			
3.3.2.86	Generation of CA keys shall occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS. Such cryptographic devices perform key generation using a random number generator (RNG) or pseudo random number generator (PRNG).	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are	Mandatory	WebTrust 4.1.1. CA Browser Forum 6.1			

CC AUDIT REPORT

		independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					
3.3.2.87	The key generation process shall generate statistically random key values that are resistant to known attacks	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	IT CA Rules SCHEDULE III 18.1			
3.3.2.88	The Certifying Authority shall use methods, which are approved by the Controller, to verify the identity of a subscriber before issuing or renewing any Public Key Certificate. The subscriber's key pair shall be generated by the subscriber or on a key generation system in the presence of the subscriber.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used	Mandatory	IT CA Rules SCHEDULE III 18.1, IT Regulations 3			

CCA - AUDIT REPORT

		f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					

3.4. Security Guidelines for Certifying Authorities

3.4.1. Network Communication Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Network Administrator							
3.4.1.1	Intrusion detection tools should be deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	IT CA Rules SCHEDULE III 8			
3.4.1.2	Communication between the Certifying Authority systems connected on a network shall be secure to ensure confidentiality and integrity of the information. For example, communications between the Certifying Authority's systems connected on a network should be encrypted and digitally signed	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	IT CA Rules SCHEDULE III 8			
3.4.1.3	Systems performing the Digital Signature Certification function should be isolated to minimise their	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured	Mandatory	T CA Rules SCHEDULE III 8			

CCA - AUDIT REPORT

	exposure to attempts to compromise the confidentiality, integrity and availability of the certification function.	(encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner					
3.4.1.4	Network connections should be initiated by the systems performing the functions of generation and management of DigitalSignature Certificate to connect those systems performing the registration and repository functions but not vice versa. If this isnot possible, compensating controls (e.g. use of proxy servers) shall be implemented to protect the systems performing the function of generation and management of Digital Signature Certificate from potential attacks	1. Understand the network connection process and check the following: a. Network connections for CA's system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing the registration and repositoryfunctions but not vice versa	Mandatory	IT CA Rules SCHEDULE III 8			
3.4.1.5	Network connections from the Certifying Authority's system to external networks shall be restricted to only those connections which are essential to facilitate Certifying Authority's functional processes and services. Such network connections to the external network shall be properly secured and monitored regularly.	1. Understand the network connection process and check the following: a. Network connections for CA's system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing the registration and repositoryfunctions but not vice versa	Mandatory	IT CA Rules SCHEDULE III 8			
3.4.1.6	Shared computer systems, network devices used for	1. Verify secure network management system is implemented to monitor functioning of computer network	Mandatory	IT CA Rules SCHEDULE II 20			

CCA - AUDIT REPORT

	business applications shall comply with the requirement established in System Integrity and Security Measures (Section 3.1.6).	2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6					
3.4.1.7	Only authorized and legal software shall be used on the network.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20			
3.4.1.8	Secure Network Management System should be implemented to monitor functioning of the computer network. Broadcast of network traffic should be minimized.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20			
3.4.1.9	System must include a mechanism for alerting the Network Administrator of possible breaches in security, e.g., unauthorized access, virus infection and hacking.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20			
3.4.1.10	Network Administrator shall regularly undertake the review of network and also take adequate measures to provide physical, logical and procedural safeguards for its security. Appropriate follow up of any unusual activity or pattern	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20			

CCA - AUDIT REPORT

	of access on the computer network shall be investigated promptly by the Network Administrator						
3.4.1.11	Each organization shall designate a properly trained "Network Administrator" who will be responsible for operation, monitoring security and functioning of the network.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20			
Network Communication Security							
3.4.1.12	Network diagnostic tools, e.g., spectrum analyzer, protocol analyzer should be used on a need basis	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator’s approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17			
3.4.1.13	As far as possible, transmission medium within the Certifying Authority's operational site should be secured against electromagnetic transmission. In this regard, use of Optical Fibre Cable and armored cable	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator’s approval was taken b. Changes were documented	Mandatory	IT CA Rules SCHEDULE II 17			

COMPLIANCE AUDIT REPORT

	may be preferred as transmission media as the case may be.	c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis					
3.4.1.14	Prior authorization of the Network Administrator shall be obtained for making any changes to network configuration. The changes made in the network configuration shall be documented. The threat and risk assessment of the network after changes in the network configuration shall be reviewed. The network operation shall be monitored for any security irregularity. A formal procedure should be in place for identifying and resolving security problems.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17			
3.4.1.15	The network configuration and inventories shall be documented and maintained.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17			

CCA - AUDIT REPORT

3.4.1.16	All sensitive information on the network shall be protected by using appropriate techniques. The critical network devices such as routers, switches and modems should be protected from physical damage	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17			

3.4.2. Technical Security Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Activation Data							
3.4.2.1	All CA and CSP components shall regularly synchronize with a time service such as Indian Standard Time Service. Time derived from the time service shall be used for establishing the time of: • Initial validity time of a Subscriber's Certificate • Revocation of a Subscriber's Certificate • Posting of CRL updates • OCSP or other CSP responses	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.8			
3.4.2.2	CAs, CSPs, shall change the activation data whenever the token is re-keyed or returned from maintenance	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys	Mandatory	X.509 Policy 6.4.3			

CCA AUDIT REPORT

		is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4					
3.4.2.3	Data used to unlock private keys shall be protected from disclosure. After a predetermined number of failed login attempts, a facility to temporarily lock the account shall be provided	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.4.2			
3.4.2.4	The activation data used to unlock private keys, in conjunction with any other access control, shall have an appropriate level of strength for the keys or data to be protected and shall meet the applicable security policy requirements of the cryptographic module used to store the keys. Activation data may be user selected. If the activation data must be transmitted, it shall be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.4.1			

CCA - AUDIT REPORT

3.4.3. Connectivity

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Connectivity							
3.4.3.1	No Internet access should be allowed to database server/ file server or server hosting sensitive data.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19			
3.4.3.2	The suitability of new hardware/software particularly the protocol compatibility should be assessed before connecting the same to the organization's network.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19			
3.4.3.3	All unused connections and network segments should be disconnected from active networks. The computer system/personal computer or outside terminal accessing an organization's host system must adhere to the general system security and access	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is	Mandatory	IT CA Rules SCHEDULE II 19			

CCA AUDIT REPORT

	control guidelines	assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data					
3.4.3.4	Organization shall establish procedure for allowing connectivity of their computer network or computer system to non-organization computer system or networks. The permission to connect other networks and computer system shall be approved by the Network Administrator and documented	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19			

3.4.4. Firewalls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Firewalls							
3.4.4.1	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18			
3.4.4.2	All firewalls shall be subjected to thorough test for vulnerability prior to being put to use and at least half-yearly thereafter.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed	Mandatory	IT CA Rules SCHEDULE II 18			

COPY AUDIT REPORT

		on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.					
3.4.4.3	Networks that operate at varying security levels shall be isolated from each other by appropriate firewalls. The internal network of the organization shall be physically and logically isolated from the Internet and any other external connection by a firewall.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18			
3.4.4.4	Intelligent devices generally known as "Firewalls" shall be used to isolate organization's data network with the external network. Firewall device should also be used to limit network connectivity for unauthorized use.	1. Verify firewalls have been installed to protect the data network and to prevent unauthorized use	Mandatory	IT CA Rules SCHEDULE II 18			
3.4.4.5	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18			

3.4.5. Documentation Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Documentation Security							
3.4.5.1	Organizations shall adopt a clean desk	1. Conduct a walkthrough of the documentation security process and verify	Mandatory	IT CA Rules SCHEDULE II 16			

CCA AUDIT REPORT

	policy for papers, diskettes and other documentation in order to reduce the risks of unauthorized access, loss of and damage to information outside normal working hours.	the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented					
3.4.5.2	Documentation shall be classified according to the sensitivity of its contents/ implications	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	T CA Rules SCHEDULE II 16			
3.4.5.3	Adequate backups of all documentation shall be maintained and a copy of all critical documentation and manuals shall be stored off-site.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue	Mandatory	IT CA Rules SCHEDULE II 16			

CONFIDENTIAL AUDIT REPORT

		d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented					
3.4.5.4	Access to application software documentation and sensitive system software documentation shall be restricted to authorized personnel on a "need-to-use" basis only	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	IT CA Rules SCHEDULE II 16			
3.4.5.5	All documentation and subsequent changes shall be reviewed and approved by an independent authorized party prior to issue	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to	Mandatory	IT CA Rules SCHEDULE II 16			

COPY - NOT REPORT

		sensitivity h. Clear Desks policy has been implemented					
3.4.5.6	All documentation pertaining to application software and sensitive system software and changes made therein shall be updated to the current time, accurately and stored securely. An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	IT CA Rules SCHEDULE II 16			

3.4.6. System Software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
System Software							
3.4.6.1	Procedures to control the use of sensitive system utilities and system programmes that could bypass intended security controls shall be in place and documented. All usage shall be logged and reviewed by the System Administrator and anotherperson independent of System Administrator for dubious activities.	1. Verify documented procedure is present to control the use of sensitive system utilities and system programmes 2. Validate all usage is logged and reviewed by the System Administrator and another person independent of System Administrator for dubious activities	Mandatory	IT CA Rules SCHEDULE II 15			

CCA - AUDIT REPORT

3.4.6.2	System Programmers shall not be allowed to have access to the application system's data and programme files in the production environment	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			
3.4.6.3	There shall be no standing "Write" access to the system libraries. All "Write" access shall be logged and reviewed by the System Administrator for dubious activities.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			

CCA AUDIT REPORT

3.4.6.4	A log of all changes to system software shall be maintained, completely documented and tested to ensure the desired results.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			
3.4.6.5	All changes proposed in the system software must be appropriately justified and approved by an authorized party	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			

CCA AUDIT REPORT

3.4.6.6	Versions of system software installed on the computer system and communication devices shall be regularly updated	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			
3.4.6.7	All vendor supplied default user IDs shall be deleted or password changed before allowing users to access the computer system	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			

CCA AUDIT REPORT

3.4.6.8	System software shall be comprehensively tested and its security functionality validated prior to implementation.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			
3.4.6.9	All system software options and parameters shall be reviewed and approved by the management.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15			

CCA AUDIT REPORT

3.4.7. Purchase and Licensing of Hardware and Software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Purchase and Licensing of Hardware and Software							
3.4.7.1	Illegally acquired or unauthorized software must not be used on any computer, computer network or data communication equipment. In the event that any illegally acquired or unauthorized software is detected by the System Administrator or Network Administrator, the same must be removed	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14			
3.4.7.2	No software will be installed and used on the system when appropriate licensing agreements do not exist, except during evaluation periods for which the user has documented permission to install and test the software under evaluation.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14			
3.4.7.3	It is prohibited to knowingly install on any system whether test or production, any software which is not licensed for use on the specific systems or networks.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14			
3.4.7.4	There shall be procedures to identify, select, implement and control software (system and application software) acquisition and	1. Validate procedures have been implemented to identify, select, implement and control software (system and application software) acquisition and installation 2. Check that it is in compliance with the Indian Copyright Act and Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 14			

CCA - AUDIT REPORT

	installation to ensure compliance with the Indian Copyright Act and Information Technology Security Guidelines.						
3.4.7.5	Software, which is capable of bypassing or modifying the security system or operating system, integrity features, must be verified to determine that they conform to these Information Technology Security Guidelines. Where such compliance is not possible, then procedures shall be in place to ensure that the implementation and operation of that software does not compromise the security of the system.	1. Verify procedures have been implemented to ensure that the implementation and operation of that software does not compromise the security of the system	Mandatory	IT CA Rules SCHEDULE II 14			
3.4.7.6	Hardware and software products that contain or are to be used to enforce security, and intended for use or interface into any organization system or network, must be verified to comply with these Information Technology Security Guidelines prior to the signing of any contract, purchase or lease.	Validate the hardware and software products comply with the Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 14			

3.4.8. Hardware and software maintenance

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Hardware and software maintenance							
3.4.8.1	Maintenance personnel will sign non-disclosure agreements	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT	Mandatory	IT CA Rules SCHEDULE II 13			

CCA AUDIT REPORT

		equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.4.8.2	Organization must enter into maintenance agreements, if necessary, with the supplier of computer and communication hardware, software (both system and application) and firmware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.4.8.3	It shall be the responsibility of the officer in charge of the operational site to ensure that contract for annual maintenance of hardware is always in place.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air	Mandatory	IT CA Rules SCHEDULE II 13			

CCA - AUDIT REPORT

		conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.4.8.4	Organization must make proper arrangements for maintenance of computer hardware, software (both system and application) and firmware installed and used by them	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.4.8.5	Provision of an uninterruptible power supply.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			

CCA - AUDIT REPORT

3.4.8.6	Identification of support facilities including power and air conditioning	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.4.8.7	Authorization, documentation, and control of change made to the hardware	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.4.8.8	Identification and use of security features implemented within hardware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is	Mandatory	IT CA Rules SCHEDULE II 13			

COA - AUDIT REPORT

		defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.4.8.9	Maintenance of an inventory and configuration chart of hardware	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.4.8.10	Proper placement and installation of Information Technology equipment to reduce the effects of interference due to electromagnetic emanations.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance	Mandatory	IT CA Rules SCHEDULE II 13			

CCA - AUDIT REPORT

		personnel have signed non-disclosure agreements					

3.4.9. Relocation of hardware and software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Relocation of hardware and software							
3.4.9.1	Whenever computers or computer peripherals are relocated (e.g. for maintenance, installation at different sites or storage), the following guidelines shall apply: • All removable media will be removed from the computer system and kept at secure location. • Internal drives will be overwritten, reformatted or removed as the situation may be. • If applicable, ribbons will be removed from printers. • All paper will be removed from printers.	1. Perform walkthrough and verify Relocation of hardware and software is performed as per requirements mentioned in the control description	Mandatory	IT CA Rules SCHEDULE II 12			

3.4.10. Measures to handle computer virus

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Measures to handle computer virus							
3.4.10.1	An awareness and training programme shall be established to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	1. Verify by checking procedures are established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	Mandatory	IT CA Rules SCHEDULE II 11			
3.4.10.2	Procedures shall be	1. Verify by checking procedures are	Mandatory	IT CA Rules SCHEDULE II 11			

CCA AUDIT REPORT

	established to limit the spread of viruses to other organization information assets. Such procedures inter alia shall include: • Communication to other business partners and users who may be at risk from an infected resource • Eradication and recovery procedures • Incident report must be documented and communicated per established procedures	established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities					
3.4.10.3	A team shall be designated to deal with reported or suspected incidents of computer virus. The designated team shall ensure that latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.	1. Verify a team is established for incidents management of computer virus 2. Validate the team ensures latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.	Mandatory	IT CA Rules SCHEDULE II 11			
3.4.10.4	All diskettes and software shall be screened and verified by virus detection software before being loaded onto the computer system. No magnetic media like tape cartridge, floppies etc. brought from outside shall be used on the data, file, PKI or computer server or personal computer on Intranet and Internet without proper screening and verification by virus detection software	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software	Mandatory	IT CA Rules SCHEDULE II 11			

CCA AUDIT REPORT

3.4.10.5	Virus detection software must be used to check storage drives both internal and external to the system on a periodic basis	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software	Mandatory	IT CA Rules SCHEDULE II 11			
3.4.10.6	Responsibilities and duties shall be assigned to ensure that allfile servers and personal computers are equipped with up-to- date virus protection and detection software.	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software	Mandatory	IT CA Rules SCHEDULE II 11			
3.4.10.7	Detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented. Employee awareness programs are in place.	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are	Mandatory	WebTrust 3.5.8			

COPY AUDIT REPORT

		screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software					

3.4.11. Operations Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Operations Management							
3.4.11.1	Acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.7			
3.4.11.2	Capacity demands are monitored and projections of future capacity requirements made to ensure that adequate processing power and storage are available.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.6			

COPY AUDIT REPORT

3.4.11.3	Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.5			
3.4.11.4	Development and testing facilities are separated from operational facilities	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.4			
3.4.11.5	Duties and areas of responsibility are segregated in order to reduce opportunities for unauthorized modification or misuse of information or services	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable	Mandatory	WebTrust 3.5.3			

COA - AUDIT REPORT

		tests of the system carried out prior to acceptance					
3.4.11.6	Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.2			
3.4.11.7	CA operating procedures are documented and maintained for each functional area.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.1			

3.4.12. Change Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Review Of Changes							
3.4.12.1	Information on the software updates and patches and their implementation on Certifying Authority's system	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the	Mandatory	IT CA Rules SCHEDULE III 7			

COMPLIANCE AUDIT REPORT

	shall be clearly and properly documented	production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
3.4.12.2	Software updates and patches to rectify security vulnerability in critical systems used for Certifying Authority's operation shall be promptly reviewed and implemented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE III 7			
3.4.12.3	Software updates and patches shall be reviewed for security implications before being implemented on Certifying Authority's system	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved	Mandatory	IT CA Rules SCHEDULE III 7			

CCA - AUDIT REPORT

		3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
3.4.12.4	Periodic management reports on the status of the changes implemented in the computer resourced in the production system shall be submitted for management review	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3			
3.4.12.5	All emergency changes/fixes in computer resource in the production system shall be reviewed and approved	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches	Mandatory	IT CA Rules SCHEDULE II 21.3			

COAT AUDIT REPORT

		are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
3.4.12.6	Procedures shall be established to schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3			
3.4.12.7	Procedures shall be established for an independent review of programme changes before they are moved into a production environment to detect unauthorized or malicious codes	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented	Mandatory	IT CA Rules SCHEDULE II 21.3			

COA AUDIT REPORT

		6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
Testing Of Changes To Production System							
3.4.12.8	All user acceptance tests in respect of changes in computer resource in production system shall be performed in a controlled environment which includes: (i) Test objectives, (ii) A documented test plan, and (iii) acceptance criteria.	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	Mandatory	IT CA Rules SCHEDULE II 21.2			
3.4.12.9	All changes in computer resource proposed in the production system shall be tested and the test results shall be reviewed and accepted by all concerned parties prior to implementation.	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	Mandatory	IT CA Rules SCHEDULE II 21.2			
Change Management							
3.4.12.10	Version changes of application software and all system software installed on the computer systems and all communication devices shall be documented. Different versions of application software and system software must be kept in safe custody	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes	Mandatory	IT CA Rules SCHEDULE II 21.1			

COMPLIANCE AUDIT REPORT

		made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.11	Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation shall be documented and implemented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1			
3.4.12.12	Fall-back procedures in the event of a failure in the implementation of the change process shall be established and documented.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes	Mandatory	IT CA Rules SCHEDULE II 21.1			

COPY AUDIT REPORT

		b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.13	Owners/Users shall be notified of all changes made to production system which may affect the processing of information on the said production system	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented	Mandatory	IT CA Rules SCHEDULE II 21.1			

COPY AUDIT REPORT

		k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.14	No changes to a production system shall be implemented until such changes have been formally authorised. Authorisation procedures for change control shall be defined and documented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1			
3.4.12.15	A risk and impact analysis, classification and prioritisation process shall be established	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and	Mandatory	IT CA Rules SCHEDULE II 21.1			

COMPTROLLER AND AUDITOR GENERAL REPORT

		tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.16	Organizational responsibilities for the change management process shall be defined and assigned	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and	Mandatory	IT CA Rules SCHEDULE II 21.1			

COPY OF DIT REPORT

		implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.17	The implementation of changes is strictly controlled by the use of formal change control procedures to minimize the risk of corruption of information systems.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	WebTrust 3.7.7			
3.4.12.18	Application systems are reviewed and tested when operating system changes occur	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change	Mandatory	WebTrust 3.7.6			

COMPLIANCE AUDIT REPORT

		control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.4.12.19	Change control procedures exist and are followed for the hardware, network component, and system configuration changes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	WebTrust 3.7.3			

COPY AUDIT REPORT

3.4.12.20	Software testing and change control procedures exist and are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	WebTrust 3.7.2			

3.4.13. Business Practices Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CP and CPS Consistency							
3.4.13.1	All changes in Certificate Policy and certification practice statement shall be published on the web site of the Certifying Authority and brought to the notice of the Controller well in advance of such publication. However any change shall not	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	IT Regulations 3			

CCA AUDIT REPORT

	contravene any provision of the Act, rule or regulation or made there under.						
3.4.13.2	A defined review process exists to ensure that Certificate Policy(s) are supported by the CA's CPS.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.4			
3.4.13.3	The CA assesses the impact of proposed CPS changes to ensure that they are consistent with the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.3			
3.4.13.4	The CA addresses the requirements of the CP when developing its CPS	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.2			
3.4.13.5	The PA is responsible for ensuring that the CA's control processes, as stated in a Certification Practice Statement (CPS) or equivalent, fully comply with the requirements of the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.1			
Certificate Policy (CP) Management							
3.4.13.6	The PA makes available the Certificate Policies supported by the CA to Subscribers and Relying Parties	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.5			
3.4.13.7	A defined review process exists to assess that the Certificate Policy(s) are capable of support by the controls specified in the CPS.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.4			
3.4.13.8	Certificate Policy(s) are approved by the Policy Authority in accordance with a defined annual review process, including responsibilities for maintaining and tracking changes to the Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.3			

CCA - AUDIT REPORT

3.4.13.9	The PA has final authority and responsibility for specifying and approving Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.2			
3.4.13.10	The Policy Authority (PA) has the responsibility of defining the business requirements and policies for using digital certificates and specifying them in a Certificate Policy (CP) and supporting agreements	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.1			
Certification Practice Statement (CPS) Management							
3.4.13.11	The CA updates its CPS to reflect changes in the environment as they occur	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.6			
3.4.13.12	Revisions to the CA's CPS are made available to appropriate parties.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.5			
3.4.13.13	The CA makes available its Certification Practice Statement (CPS) to all appropriate parties	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as	Mandatory	WebTrust 2.1.4			

CCA - AUDIT REPORT

		per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required					
3.4.13.14	The CA's CPS is modified and approved in accordance with a defined review process.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.3			
3.4.13.15	Responsibilities for maintaining the CPS have been formally assigned.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.2			
3.4.13.16	The Policy Authority (PA) has final authority and responsibility for approving the CA's Certification Practice Statement (CPS).	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.1			
3.4.13.17	The Certification Practice Statement of the Certifying Authority shall comply with, and be governed by, the laws of the country	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals.	Mandatory	IT CA Rules 18			

CCA AUDIT REPORT

		d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required					

3.4.14. CA Business Practices Disclosure

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CA Business Practices Disclosure							
3.4.14.1	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 or RFC 2527 in its Certificate Policy (CP)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.2			
3.4.14.2	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 in its Certification Practice Statement (CPS)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.1			

3.5. Information Technology (IT) Security Guidelines

3.5.1. Licensing of Certifying Authorities

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Licensing of CA Authorities							
3.5.1.1	The method of verification of the identity of the applicant of a Public Key Certificates shall be commensurate with the level of assurance accorded to the certificate.	1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate	Mandatory	IT Regulations 3			
3.5.1.2	The Certifying Authority shall comply with every order or direction issued	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit,	Mandatory	IT Regulations 3			

CCA - AUDIT REPORT

	by the Controller within the stipulated period.	verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.5.1.3	The Certifying Authority shall always assure the confidentiality of subscriber information	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.	Mandatory	IT Regulations 3			
3.5.1.4	The Certifying	1. Verify the following:	Mandatory	IT Regulations 3			

CCA AUDIT REPORT

	Authority shall subject itself to periodic audits to ensure that all conditions of the licence are consistently complied with by it. As the cryptographic components of the Certifying Authority systems are highly sensitive and critical, the components must be subjected to periodic expert review to ensure their integrity and assurance.	a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.5.1.5	The Certifying Authority shall be bound to comply with all the parameters against which it was audited prior to issue of licence and shall consistently and continuously comply with those parameters during the period for which the licence shall remain valid.	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated	Mandatory	IT Regulations 3			

COPY - AUDIT REPORT

		period.					
3.5.1.6	The Controller can revoke or suspend the licence in accordance with the provisions of the Act	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.	Mandatory	IT Regulations 3			
3.5.1.7	The license shall be valid for a period of five years from the date of issue. The license shall not be transferable or heritable	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits	Mandatory	IT Regulations 3			

COMPLIANCE AUDIT REPORT

		i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.5.1.8	The applicant being an individual, or a company, or a firm under sub-rule shall submit a performance bond or furnish a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as may be approved by the Controller for an amount of 50 lakhs/ 01 croreof rupees and the performance bond or banker's guarantee shall remain valid for a period of six years from the date of its submission	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.	Mandatory	IT CA Rules 8			
3.5.1.9	The following persons may apply for grant of a license to issue Digital Signature Certificates, namely:- • an individual, being a citizen of India and having a capital of five crores of rupees or more in his business or profession; • a company having– o paid up capital of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period	Mandatory	IT CA Rules 8, IT Regulations 3			

CCA - AUDIT REPORT

	• a firm having – o capital subscribed by all partners of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees • Central Government or a State Government or any of the Ministries or Departments, Agencies or Authorities of such Governments.	for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.5.1.10	To ensure the integrity of its digital certificates, the Certifying Authority shall ensure the use of approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival	1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate	Mandatory	IT Regulations 3 3			

3.5.2. Compliance Audit and Other Assessments

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Communication of results							
3.5.2.1	An Audit Report, including identification of corrective measures taken or being taken by the CA, shall be provided to the Controller (in case of grant of license and its renewal) and the audited CA (in case of annual audit). The report	1. Verify the audit reports are submitted to CCA and the audited CA 2. Validate the report identifies the versions of the CP and CPS used in the assessment	Mandatory	CA Browser Forum 8.6, X.509 Policy 8.6			

CCA AUDIT REPORT

	shall identify the versions of the CP and CPS used in the assessmen						
Actions taken as a result of deficiency							
3.5.2.2	When the auditor finds a discrepancy between how the CA is designed or is being operated or maintained, and the requirements of this CP, or the applicable CPS, the auditor shall take the following actions: • The auditor shall note the discrepancy; • The auditor shall notify the audited CA; and • The auditor shall notify the office of CCA.	1. For sample discrepancies raised by the auditor, verify the following actions were taken by the auditor: a. auditor noted discrepancy; b. The auditor notified the audited CA; and c. The auditor notified the office of CCA.	Mandatory	CA Browser Forum 8.5, X.509 Policy 8.5			
Topics covered by assessment							
3.5.2.3	CAs shall have a compliance audit mechanism in place to ensure that the requirements of this CP and applicable CPS are being implemented and enforced.	1. Obtain details of the compliance audit mechanism to verify requirements of this CP and applicable CPS are being implemented and enforced	Mandatory	CA Browser Forum 8.4, X.509 Policy 8.4			
Assessor's relationship to assessed entity							
3.5.2.4	The auditor shall be a firm, which is independent from the entity being audited. The Controller shall determine whether an auditor meets this requirement	1. Verify the auditor is a firm, independent from CA 2. Validate the CCA verifies auditor meets above requirement	Mandatory	CA Browser Forum 8.3, X.509 Policy 8.3			
Identity/qualifications of assessor							
3.5.2.5	The CA’s audit shall be performed by a Qualified Auditor. A Qualified Auditor means a natural person, Legal Entity, or group of natural persons or Legal Entities that	1. Validate that the audit was performed by only by the CCA empaneled agency and auditors. 2. Check the auditor is be independent of the CA being audited	Mandatory	CA Browser Forum 8.2			

CCA - AUDIT REPORT

	collectively possess the following qualifications and skills: • Independence from the subject of the audit • The ability to conduct an audit that addresses the criteria specified in an Eligible Audit Scheme • Employs individuals who have proficiency in examining Public Key Infrastructure technology, information security tools and techniques, information technology and security auditing, and the third party attestation function; • For audits conducted in accordance with any one of the ETSI standard, accredited in accordance with ISO 17065 applying the requirements specified in ETSI EN 319 403; • For audits conducted in accordance with the WebTrust standard, licensed by WebTrust • Bound by law, government regulation, or professional code of ethics; and • Except in the case of an Internal Government Auditing Agency, maintains Professional Liability/Errors						
Frequency or circumstances of assessment							
3.5.2.6	The point-in-time readiness assessment shall be completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates and shall be followed by a	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12)	Mandatory	CA Browser Forum 8.1			

CCSS AUDIT REPORT

	complete audit under such scheme within ninety (90) days of issuing the first Publicly-Trusted Certificate.	months prior to issuing Publicly- Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly- Trusted Certificate.					
3.5.2.7	If the CA does not have a currently valid Audit Report indicating compliance with the applicable audit schemes, then, before issuing Publicly-Trusted Certificates, the CA shall successfully complete a point-in-time readiness assessment performed in accordance with applicable standards.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly- Trusted Certificate.	Mandatory	CA Browser Forum 8.1			
3.5.2.8	The period during which the CA issues Certificates shall be divided into an unbroken sequence of audit periods. An audit period must NOT exceed one year in duration.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly- Trusted Certificate.	Mandatory	CA Browser Forum 8.1			

3.5.3. Audit Logging

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Vulnerability Assessments							
3.5.3.1	Events in the audit process are logged, in part, to monitor system vulnerabilities. The Certifying Authority must ensure that a vulnerability assessment is performed, reviewed and revised, if necessary, following an examination of these monitored events.	1. Verify the events in the audit process are logged, in part, to monitor system vulnerabilities	Mandatory	IT CA Rules SCHEDULE III 9.6			
Audit Log Backup Procedures							

CCA - AUDIT REPORT

3.5.3.2	Audit logs and audit summaries must be backed up or copied if in manual form.	1. Validate audit logs and summaries are backed up and copied if in manual form	Mandatory	IT CA Rules SCHEDULE III 9.5			
Audit Trails and Verification							
3.5.3.3	Computer records of applications transactions and significant events must be retained for a minimum period of two years or longer depending on specific record retention requirements.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10			
3.5.3.4	Computer system access records shall be kept for a minimum of two years, in either hard copy or electronic form. Records, which are of legal nature and necessary for any legal or regulation requirement or investigation of criminal behavior, shall be retained as per laws of the land	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10			
3.5.3.5	The real time clock of	1. Verify on sample basis the	Mandatory	IT CA Rules SCHEDULE II 10			

CCA AUDIT REPORT

	the computer or communications device shall be set to Indian Standard Time (IST). Further there shall be a procedure that checks and corrects drift in the real time clock.	transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
3.5.3.6	The real time clock of the computer system shall be set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10			
3.5.3.7	Automated or manual procedures shall be used to monitor and promptly report all significant security events, such as accesses, which are out-of pattern relative to time, volume, frequency, type of information asset, and redundancy. Other areas	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual	Mandatory	IT CA Rules SCHEDULE II 10			

CCA - AUDIT REPORT

	of analysis include: • Significant computer system events (e.g. configuration updates, system crashes) • Security profile changes • Actions taken by computer operations, system administrators, system programmers, and/or security administrators	procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
3.5.3.8	Adequate audit trails shall be captured and certain information needed to determine sensitive events and pattern analysis that would indicate possible fraudulent use of the system (e.g. repeated unsuccessful logons, access attempts over a series of days) shall be analyzed. This information includes such information as who, what, when, where, and any special information such as: • Success or failure of the event • Use of authentication keys, where applicable	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10			
3.5.3.9	Transactions that meet exception criteria shall be completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two	Mandatory	IT CA Rules SCHEDULE II 10			

CCA - AUDIT REPORT

		years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
Procedures to Obtain & Verify Archive Information							
3.5.3.10	Procedures detailing how to create, verify, package, and transmit archive information shall be published in the applicable CPS.	1. Verify for archived information, procedures have been established to perform following activities: a. Creation b. Verification c. Packaging d. Transmission	Mandatory	X.509 Policy 5.5.7			
Requirements for Time-Stamping of Records							
3.5.3.11	The Certifying Authority shall provide Time Stamping Service for its subscribers. Error of the Time Stamping clock shall not be more than 1 in 109. Archived records shall be time stamped such that order of events can be determined	1. Verify the VA provides time stamping service for its subscribers with error of the Time Stamping clock less than 1 in 109 . 2. Validate on a sample basis that logs in the archive are time stamped	Mandatory	X.509 Policy 5.5.5, IT Regulations 3			
Protection of Archive							
3.5.3.12	Archive media shall be stored in a safe, secure storage facility separate from the component (CA, CSP, or RA) with physical and procedural security controls equivalent or better than those for component	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3			
3.5.3.13	The contents of the archive shall not be released except as determined by the CCA, the Licensed CA, or as required by law. Records of individual may be released upon request of any subscribers involved in the transaction or their legally recognized agents.	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3			

CCA AUDIT REPORT

3.5.3.14	No unauthorized user shall be permitted to write to, modify, or delete the archive. For the CA and CSP, the authorized individuals are Audit Administrators. For the RA, authorized individuals are someone other than the RA (e.g., Information Assurance Officer or IAO).	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3			
Records Archival							
3.5.3.15	CA, CSP, and RA archive records shall be sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Mandatory	X.509 Policy 5.5.1			
3.5.3.16	Information stored off-site must be periodically verified for data integrity	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place	Mandatory	IT CA Rules SCHEDULE III 10			

CCA IT AUDIT REPORT

		4. Verify all information pertaining to CA’s operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA’s permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
3.5.3.17	All information pertaining to Certifying Authority's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement shall be stored within the country. This information shall be taken out of the country only with the permission of Controller and where a properlyconstitutional warrant or such other legally enforceable document is produced	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA’s operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA’s permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Mandatory	IT CA Rules SCHEDULE III 10			
3.5.3.18	A second copy of all information retained or backed up must be stored at three locations within the country including the Certifying Authority site and must be protected either by physical security alone, or a combination of physical and cryptographic protection. These secondary sites must provide adequate protection from environmental threats such as temperature, humidity and	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA’s operation, Subscriber's application,	Mandatory	IT CA Rules SCHEDULE III 10			

CCA - AUDIT REPORT

	magnetism. The secondary site should be reachable in few hours	verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
3.5.3.19	Audit information, subscriber agreements, verification, identification and authentication information in respect of subscriber shall be retained for at least seven years	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Mandatory	IT CA Rules SCHEDULE III 10			
3.5.3.20	Digital Signature Certificates stored and generated by the Certifying Authority must be retained for at least seven years after the date of its expiration. This requirement does not include the backup of private signature keys. Public Key Certificates and Certificate Revocation Lists must be archived for a minimum period of seven years to enable verification of past transactions	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement	Mandatory	IT CA Rules SCHEDULE III 10, IT Regulations 3			

CCA AUDIT REPORT

		is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
Protection of Audit Logs							
3.5.3.21	It shall be acceptable for the system to over-write audit logs after they have been backed up and archived	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration	Mandatory	X.509 Policy 5.4.4			
3.5.3.22	System configuration and procedures shall be implemented together to ensure that: • Only authorized people have read access to the logs; • Only authorized people may archive audit logs; and, • Audit logs are not modified.	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration	Mandatory	X.509 Policy 5.4.4			
3.5.3.23	The electronic audit log system must include mechanisms to protect the log files from unauthorized viewing, modification, and deletion. Manual audit information must be protected from unauthorised viewing, modification and destruction	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration	Mandatory	IT CA Rules SCHEDULE III 9.4			
Frequency of Processing Audit Logs							
3.5.3.24	The Audit Administrator shall explain all significant events in an audit log summary. Actions taken as a result of reviews involving verifying that the log has not been tampered with, there is	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator	Mandatory	X.509 Policy 5.4.2			

COMPLIANCE AUDIT REPORT

	no discontinuity or other loss of audit data, and then briefly inspecting all log entries shall be documented.	explains all significant events in an audit log summary					
3.5.3.25	Audit logs shall be reviewed at least once every 30 days. Statistically Significant sample of security audit data generated by the CA, CSP, or RA since the last review shall be examined (where the confidence intervals for each category of security audit data are determined by the security ramifications of the category and the availability of tools to perform such a review), as well as a reasonable search for any evidence of malicious activity.	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary	Mandatory	X.509 Policy 5.4.2			
3.5.3.26	The Certifying Authority must ensure that its audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary. Such reviews should involve verifying that the log has not been tampered with, and then briefly inspecting all log entries, with a more thorough investigation of any alerts or irregularities in the logs. Action taken following these reviews must be documented	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary	Mandatory	IT CA Rules SCHEDULE III 9.2			
Types of Events Recorded							
3.5.3.27	The audit record shall include the following (either recorded automatically or manually for each auditable event): • The type of event, • The date and time the event occurred• Success or failure where appropriate, and • The identity of the entity and/or operator that caused the even	1. For sample audit records, check the following are included: a. The type of event, b. The date and time the event occurred, c. Success or failure where appropriate, and d. The identity of the entity and/or operator that caused the even	Mandatory	X.509 Policy 5.4.1			

CCA AUDIT REPORT

3.5.3.28	Log entries shall include the following elements: • Date and time of entry; • Identity of the person making the journal entry; and • Description of the entry.	1. For sample log entries, check the following are recorded: a. Date and time of entry; b. Identity of the person making the journal entry; and c. Description of the entry.	Mandatory	CA Browser Forum 5.4.1			
3.5.3.29	A Certifying Authority should also collect and consolidate, either electronically or manually, security information which may not be generated by his system, such as: • Physical access logs; • System configuration changes and maintenance; • Personnel changes; • Discrepancy and compromise reports; • Records of the destruction of media containing key material, activation data, or personal subscriber information	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location.	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.5.3.30	All logs, whether maintained through electronic or manual means, should contain the date and time of the event, and the identity of the subscriber/subordinate/ entity which caused the event	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.5.3.31	Records and log files shall be reviewed regularly for the following activities: • Misuse; • Errors; • Security violations; • Execution of privileged functions; • Change in access control lists; • Change in system configuration	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of	Mandatory	IT CA Rules SCHEDULE III 9.1			

CCA AUDIT REPORT

		subscriber/ subordinate/ entity which caused the event					
3.5.3.32	A Certifying Authority should consider the use of automated security management and monitoring tools providing an integrated view of the security situation at any point in time. Records of the following application transactions shall be maintained: • Registration; • Certification; • Publication; • Suspension; and • Revocation.	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.5.3.33	All security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP shall be enabled	1. Verify all security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP are enabled	Mandatory	X.509 Policy 5.4.1			
3.5.3.34	CA and Subscriber Certificate lifecycle management events, including the following shall be recorded: • Certificate requests, renewal, and re-key requests, and revocation; • All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; • Date, time, phone number used, persons spoken to, and end results of verification telephone calls; • Acceptance and rejection of certificate requests;Issuance of Certificates; and • Generation of Certificate Revocation Lists and OCSP entries	1. On a sample basis validate the CA and Subscriber Certificate lifecycle management events, including the following are recorded: a. Certificate requests, renewal, and re-key requests, and revocation; b. All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; c. Date, time, phone number used,persons spoken to, and end results of verification telephone calls; d. Acceptance and rejection of certificate requests; e. Issuance of Certificates; and f. Generation of Certificate Revocation Lists and OCSP entries	Mandatory	CA Browser Forum 5.4.1			
3.5.3.35	The Certifying Authority shall maintain record of all events relating to the security of his system. The	1. For sample audit log files, check the following details are recorded: a. System start-up and shutdown; b. CA's application start-up and shutdown;	Mandatory	IT CA Rules SCHEDULE III 9.1			

CCA - AUDIT REPORT

	records should be maintained in audit log file and shall include such events as: • System start-up and shutdown; • Certifying Authority's application start-up and shutdown; • Attempts to create, remove, set passwords or change the system • privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; • Changes to keys of the Certifying Authority or any of his other details; • Changes to Digital Signature Certificate creation policies, e.g. validity period; • Login and logoff attempts; • Unauthorised attempts at network access to the Certifying Authority's system; • Unauthorised attempts to access system files; • Generation of own keys; • Creation and revocation of Digital Signature Certificates; • Attempts to initialize remove, enable, and disable subscribers, and update and recover their keys; • Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List (CRL) directory	c. Attempts to create, remove, set passwords or change the system d. privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; e. Changes to keys of the CA or any of his other details; f. Changes to DSC creation policies g. Login and logoff attempts; h. Unauthorised attempts at network access i. Unauthorised attempts to access system files; j. Generation of own keys; k. Creation and revocation of DSC; l. Attempts to initialize remove, enable, and disable subscribers, and update and recover their keys; m. Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List (CRL) directory					
3.5.3.36	To facilitate decision-making, all agreements and correspondence relating to services provided by Certifying Authority should be collected and consolidated, either electronically or manually, at a single location.	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location.	Mandatory	IT CA Rules SCHEDULE III 9.1			
Audit Logging							
3.5.3.37	The Certifying Authority must maintain secure and reliable	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a	Mandatory	X.509 Policy 5.4, IT Regulations 3			

CCA AUDIT REPORT

	records and logs for activities that are core to its operations and review them regularly to detect any anomaly in the system..All security audit logs, both electronic and non-electronic, shall be retained and made available during compliance audits	Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits					
3.5.3.38	Where possible, the security audit logs shall be automatically collected. Where this is not possible, a logbook, paper form, or other physical mechanism shall be used	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	X.509 Policy 5.4			
3.5.3.39	The CA and each Delegated Third Party shall record details of the actions taken to process a certificate request and to issue a Certificate, including all information generated and documentation received in connection with the certificate request; the time and date; and the personnel involved. The CA shall make these records available to its Qualified Auditor as proof of the CA's compliance with these Requirements.	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	CA Browser Forum 5.4.1			
Retention Period for Audit Logs and Archive							
3.5.3.40	If the original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media shall be defined by the archive site.	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media is defined by the archive site	Mandatory	X.509 Policy 5.5.2			
3.5.3.41	The Certifying Authority must retain its audit logs onsite for at least twelve months	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to	Mandatory	IT CA Rules SCHEDULE III 9.3			

CCA AUDIT REPORT

		new media is defined by the archive site					

3.5.4. Disaster Recovery

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Secure facility after a natural or other type of disaster							
3.5.4.1	The Certifying Authority must establish a disaster recovery plan outlining the steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster. Where a repository is not under the control of the Certifying Authority the Certifying Authority must ensure that any agreement with the repository provides that a disaster recovery plan be established and documented by the repository.	1. Validate the CAs DR plan covers steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster 2. Verify in case the repository is not under CAs control, CA has signed an agreement with the repository provider that a disaster recovery plan be established and documented by the repositor	Mandatory	IT CA Rules SCHEDULE III 11.2			
Compromise and Disaster Recovery							
3.5.4.2	The Certifying Authority must establish business continuity procedures that outline the steps to be taken in the event of the corruption or loss of computing and networking resources, nominated website, repository, software and/or data. Where a repository is not under the control of the Certifying Authority, the Certifying Authority must ensure that any agreement with the repository provides for business continuity procedures.	1. Verify the CA has established business continuity procedures 2. Validate the procedures cover the requirements mentioned in control description	Mandatory	IT CA Rules SCHEDULE III 11.1			
Disaster Recovery/Management							

CCA - AUDIT REPORT

3.5.4.3	Disaster recovery plan should be updated regularly to ensure its continuing Effectiveness	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26			
3.5.4.4	Test plan shall be developed, documented and maintained. Periodic tests shall be carried out to test the effectiveness of the procedures in the plan. The results of the tests shall be documented for management review	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26			
3.5.4.5	Periodic training of personnel and users associated with computer system and network should be conducted defining their roles and responsibilities in the	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of	Mandatory	IT CA Rules SCHEDULE II 26			

CCA AUDIT REPORT

	event of a disaster	disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly					
3.5.4.6	Each component/aspect of the plan should have a person and a backup assigned to its execution	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	T CA Rules SCHEDULE II 26			
3.5.4.7	Responsibilities and reporting structure shall be clearly defined which will take effect immediately on the declaration of a disaster	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster	Mandatory	IT CA Rules SCHEDULE II 26			

CONSULTANT REPORT

		f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly					
3.5.4.8	Specific disaster management plan for critical applications shall be developed, documented, tested and maintained on a regular basis.	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26			
3.5.4.9	The documentation should include: • definition of a disaster; • condition for activating the plan; • stages of a crisis; • who will make decisions in the crisis • role of individuals for each component of the plan; • composition of the recovery team; and • decision making process for return to normaloperation	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented	Mandatory	IT CA Rules SCHEDULE II 26			

CC - AUDIT REPORT

		i. Results of tests are documented for management review j. DR plan is updated regularly					
3.5.4.10	Disaster recovery plan shall be developed, properly documented, tested and maintained to ensure that in the event of a failure of the information system or destruction of the facility, essential level of service will be provided. The disaster recovery framework should include: • emergency procedures, describing the immediate action to be taken in case of a major incident • fall back procedure, describing the actions to be taken to relocate essential activities or support services to a backup site • restoration procedures, describing the action to be taken to return to normal operation at the original site	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26			
Emergency Preparedness							
3.5.4.11	Emergency drills should be held periodically to ensure that the documented emergency procedures are effective.	1. Verify emergency response procedure has been developed and documented 2. Validate emergency drills are held periodically	Mandatory	IT CA Rules SCHEDULE II 23			
3.5.4.12	Emergency response procedures for all activities connected with computer operation shall be developed and documented. These procedures should be reviewed periodically	1. Verify emergency response procedure has been developed and documented 2. Validate emergency drills are held periodically	Mandatory	IT CA Rules SCHEDULE II 23			
Recovery Procedure							

C&A - AUDIT REPORT

3.5.4.13	The need for backup hardware and other peripherals should be evaluated in accordance to business needs	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs	Mandatory	IT CA Rules SCHEDULE II 24			
3.5.4.14	The business continuity plan shall be developed which inter alia include the procedures for emergency ordering of the equipment and availability of the services.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs	Mandatory	IT CA Rules SCHEDULE II 24			
3.5.4.15	Commitment shall be obtained in writing from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs	Mandatory	IT CA Rules SCHEDULE II 24			
Incident and Compromise Handling Procedures							
3.5.4.16	A help desk shall be set up to assist users in the resolution of problems. A system for recording, tracking and reporting the status of reported problems shall be established to ensure that they are promptly managed and resolved with minimal impact on	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions	Mandatory	IT CA Rules Section II 22			

COPY AUDIT REPORT

	the user of the computing resources	e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis					
3.5.4.17	Procedures for identifying, reporting and resolving problems, such as nonfunctioning of Certifying Authority's system; breaches in Information Technology security; and hacking, shall be established and communicated to all personnel concerned. It shall include emergency procedures. Periodic reports shall be submitted for management review	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	IT CA Rules Section II 22			
3.5.4.18	A formal problem management process exists that allows the types, volumes and impacts of incidents and malfunctions to be documented, quantified and monitored	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.13			
3.5.4.19	Procedures exist and are followed to assess that corrective action is taken for reported incidents	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation	Mandatory	WebTrust 3.5.12			

CCA - AUDIT REPORT

		procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis					
3.5.4.20	Procedures exist and are followed for reporting hardware and software malfunctions.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.11			
3.5.4.21	Users of CA systems are required to note and report observed or suspected security weaknesses in, or threats to, systems or services as they are detected.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.10			

COA - AUDIT REPORT

3.5.4.22	A formal security incident reporting procedure exists setting out the actions to be taken on receipt of an incident report. This includes a definition and documentation of assigned responsibilities and escalation procedures. Any incidents are reported to PA as a matter of urgency.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.9			
3.5.4.23	An incident response action plan shall be established to ensure the readiness of the Certifying Authority to respond to incidents. The plan should include the following areas: • Compromise control; • Notification to user community; (if applicable) • Revocation of affected Digital Signature Certificates; (if applicable) • Responsibilities of personnel handling incidents; • Investigation of service disruption; • Service restoration procedure; • Monitoring and audit trail analysis; and • Media and public relation	1. Verify an incident response action plan has been established by the CA 2. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			
3.5.4.24	An incident management plan shall be developed and approved by the management. The plan shall include the following areas: • Certifying Authority's	1. Obtain copy of the incident management plan 2. Verify the plan has been approved by the management 3. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			

CCA - AUDIT REPORT

	certification key compromise; • Hacking of systems and network; • Breach of physical security; • Infrastructure availability; • Fraudulent registration and generation of Digital Signature Certificates; and • Digital Signature Certificate suspension and revocation information.						

3.5.5. System integrity and security measures

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Data Centre Operations Security							
3.5.5.1	Procedures shall be established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.2			
3.5.5.2	Procedures shall be established to maintain logs of system activities. Such logs shall be reviewed by a competent independent party for indications of dubious activities. Appropriate retention periods shall be set for such logs.	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer	Mandatory	IT CA Rules SCHEDULE II 8.2			

COPY AUDIT REPORT

		operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system					
3.5.5.3	Procedures shall be established to ensure that only authorized and correct job stream and parameter changes are made.	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.2			
3.5.5.4	As far as possible, automated job scheduling should be used. Manual job scheduling should require prior approval from the competent authority	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.1			
3.5.5.5	Procedures shall be established to ensure that all changes to the job schedules are appropriately approved. The authority to approve changes to job schedules shall	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and	Mandatory	IT CA Rules SCHEDULE II 8.1			

COA AUDIT REPORT

	be clearly assigned.	parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system					
Sensitive Systems Protection							
3.5.5.6	For sensitive data, encryption of data in storage shall be considered to protect its confidentiality and integrity.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7			
3.5.5.7	For computer system processing sensitive data, access by other Organizations shall be prohibited or strictly controlled.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7			
3.5.5.8	Security tokens/smart cards/bio-metric technologies such as Iris recognition, finger print verification technologies etc. shall be used to complement the usage of passwords to access the computer system	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7			
Data and Resource Protection							
3.5.5.9	Procedures shall be implemented to ensure the secure storage or distribution of all	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved	Mandatory	IT CA Rules SCHEDULE II 8.2			

CCR - AUDIT REPORT

	outputs/reports, in accordance with procedures defined by the owners for each system	b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system					
3.5.5.10	Application Programmer shall not be allowed to access the production system	2. Validate that application programmer does not have access to the production system	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.5.5.11	For networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks	1. Verify for networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.5.5.12	The operating system or security system of the computer system shall: • Define user authority and enforce access control to data within the computer system; • Be capable of specifying, for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed.	1. Verify the operating system or security system of the computer system define user authority and enforce access control to data within the computer system Check these are capable of specifying for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed.	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.5.5.13	All information assets shall be assigned an "owner" responsible for the	1. Check the list of data assets and the corresponding owner/custodian for the same.	Mandatory	IT CA Rules SCHEDULE II 6.6			

CCA - AUDIT REPORT

	integrity of that data/resource. Custodians shall be assigned and shall be jointly responsible for information assets by providing computer controls to assist owners.						
Privileged User`s Management							
3.5.5.14	The use of user IDs for emergency use shall be recorded and approved. The passwords shall be reset after use.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	T CA Rules SCHEDULE II 6.4			
3.5.5.15	Separate user IDs shall be allowed to the user for performing privileged and normal (non-privileged) activities.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4			
3.5.5.16	Privileged user shall not be allowed to log in to the computer system from remote terminal. The usage of the computer system by the privilege	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two	Mandatory	IT CA Rules SCHEDULE II 6.4			

COMPANY AUDIT REPORT

	user shall be allowed during a certain time period.	years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use					
3.5.5.17	An audit trail of activities conducted by highly privileged users shall be maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4			
3.5.5.18	System privileges shall be granted to users only on a need-to- use basis. Login privileges for highly privileged accounts should be available only from Console and terminals situated within Console room.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4			
Password Management							
3.5.5.19	Passwords shall always be encrypted in storage to prevent unauthorized disclosure and protect them from dictionary attacks	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user	Mandatory	IT CA Rules SCHEDULE II 6.3			

COPY AUDIT REPORT

	and all known password cracking algorithms.	exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.					
3.5.5.20	Initial or reset passwords must be changed by the user upon first use. Users shall follow defined policies and procedures in the selection and use of passwords.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	WebTrust 3.6.6, IT CA Rules SCHEDULE II 6.3			
3.5.5.21	Password retries shall be limited to a maximum of three attempted logons after which the user ID shall then be revoked; for sensitive systems, the number of password retries should be limited to a maximum of two.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	IT CA Rules SCHEDULE II 6.3			
3.5.5.22	Quality standards for password shall be enforced. The quality level shall be increased progressively. The following control features shall be implemented for passwords: • Minimum of eight • characters without leading or trailing blanks; • Shall be different from the existing password and the two previous ones; • Shall be changed at least once every	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	IT CA Rules SCHEDULE II 6.3			

CCA - AUDIT REPORT

	ninety days; for sensitive system password shall be changed at least once every thirty days; and • Shall not be shared, displayed or printed. Shall have at least on number, one capital letter, one small case letter and one special character						
System Access Control							
3.5.5.23	Sensitive Operating System files, which are more prone to hackers must be protected against all known attacks using proven tools and techniques. That is to say no user will be able to modify them except with the permission of System Administrator.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2			
3.5.5.24	The startup and shutdown procedure of the security software must be Automated	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are	Mandatory	IT CA Rules SCHEDULE II 6.2			

COPY AUDIT REPORT

		implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.25	The facility to login as another user from one user's login shall be denied. However, the system should prohibit direct login as a trusted user (e.g. root in Unix, administrator in Windows NT or Windows 2000). This means that there must be a user account configured for the trusted administrator.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to	Mandatory	IT CA Rules SCHEDULE II 6.2			

CCA AUDIT REPORT

		modify systemoperated files					
3.5.5.26	Activities of all remote users shall be logged and monitored closely	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2			
3.5.5.27	Where a second level access control is implemented through the application system, password controls similar to those implemented for the computer system shall be in place .	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity	Mandatory	IT CA Rules SCHEDULE II 6.2			

COPY - AUDIT REPORT

		is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.28	Automatic time-out for terminal inactivity should be implemented	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2			
3.5.5.29	Stored passwords shall be protected by access controls from unauthorized disclosure and modification	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data	Mandatory	IT CA Rules SCHEDULE II 6.2			

COMPLIANCE AUDIT REPORT

		resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.30	Stored passwords shall be encrypted using internationally proven encryption techniques to prevent unauthorized disclosure and modification.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2			
3.5.5.31	Each user shall be	1. For the system access controls	Mandatory	IT CA Rules SCHEDULE II 6.2			

CCA - AUDIT REPORT

	assigned a unique user ID. Adequate user education shall be provided to help users in password choice and password protection. Sharing of user IDs shall not be allowed	implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.32	An Access Control System manual documenting the access granted to different level of users shall be prepared to provide guidance to the System Administrator for grant of access.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one	Mandatory	IT CA Rules SCHEDULE II 6.2			

COPY AUDIT REPORT

		user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.33	The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use of common passwords such as "administrator" or "president" or "game" etc. to protect access to the system and data resources represent a security exposure and shall be avoided. All passwords used must be resistant to dictionary attacks.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2			
3.5.5.34	The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use of common passwords such as "administrator" or "president" or "game" etc. to protect	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.	Mandatory	IT CA Rules SCHEDULE II 6.2			

COPY AUDIT REPORT

		f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.5.5.35	Access control software and system software security features shall be implemented to protect resources. Management approval is required to authorize issuance of user identification (ID) and resource privileges. Approved access and integrity controls such as intrusion detection, virus scanning, prevention of denial-of service attacks and physical security measures shall be followed by the Certifying Authority for all its systems that store and process the subscribers' information and certificates.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files	Mandatory	IT CA Rules SCHEDULE II 6.2, IT Regulations 3			
Use of Security Systems or Facilities							
3.5.5.36	Any system software or resource of the	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system	Mandatory	IT CA Rules SCHEDULE II 6.1			

COA AUDIT REPORT

	computer system should only be accessible after being authenticated by access control system	2. Validate system software or resource of the computer system is accessible after being authenticated by access control system					
3.5.5.37	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1			
3.5.5.38	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1			
User`s Account Management							
3.5.5.39	User accounts shall be suspended under the following conditions • When an individual is on extended leave or inactive use of over thirty days. In case of protected computer system, the limit of thirty days may be reduced tofifteen days by the System Administrator. • Immediately upon the termination of the services of an individual. • Suspended or	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			

CONFIDENTIAL AUDIT REPORT

	inactive accounts shall be deleted after a two months period. In case of protected computer systems, the limit of two months may be reduced to one month.						
3.5.5.40	User accounts shall be suspended under the following conditions	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.5.5.41	A periodic check shall be carried out for redundant user accounts and access rights that are no longer required. Redundant user accounts shall not be re-issued to another user	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.5.5.42	Access rights of users who have been transferred, or left the organization shall be removed	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services	Mandatory	IT CA Rules SCHEDULE II 6.5			

COPY - AUDIT REPORT

	immediately	c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met					
3.5.5.43	A formal record of all registered users of the computer services shall be maintained.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.5.5.44	Where access to computer services is administered by service providers, access shall not be provided until authorization is completed. This shall include the acknowledgment of receipt of the accounts by the users	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			

COA-AUDIT REPORT

3.5.5.45	All users shall be required to sign an undertaking to acknowledge that they understand the conditions of access	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.5.5.46	A written statement of access rights shall be given to all users.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.5.5.47	Users shall be authorized by the computer system owner to access the computer services	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately	Mandatory	IT CA Rules SCHEDULE II 6.5			

COA - AUDIT REPORT

		h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met					
3.5.5.48	Procedures for user account management shall be established to control access to application systems and data	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			

3.5.6. Personnel Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Personnel Security							
3.5.6.1	All personnel in Trusted Roles shall maintain skill levels consistent with the CA's training and performance programs.	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs	Mandatory	CA Browser Forum 5.3.4			
3.5.6.2	Personnel appointed to trusted roles (CA trusted roles) shall: • Have successfully completed an appropriate training program; • Have demonstrated the ability to perform their duties; • Be trustworthy; • Have no other duties that would interfere or conflict with their duties for	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs	Mandatory	X.509 Policy 5.3.1			

CCA AUDIT REPORT

	the trusted role; • Have not been previously relieved of duties for reasons of negligence or nonperformance of duties; • Have not been denied a security clearance, or had a security clearance revoked for cause; • Have not been convicted of a felony offense; and • Be appointed in writing by an approving authority • Be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information;						
3.5.6.3	The CA and CSP shall make available to its personnel this certificate policy, the applicable CPS, and any relevant statutes, policies or contracts	1. Verify the CA and CSP share all relevant statutes, policies or contracts with their personne	Mandatory	X.509 Policy 5.3.7			
3.5.6.4	Prior to the engagement of any person whether as an employee, agent, or an independent contractor of the CA, the CA shall verify perform a background check. The scope of the background check shall include the following areas covering the past five years: • Employment; • Education (Regardless of the date of award, the highest educational degree shall be verified); • Place of residence (3 years); • Law Enforcement; and • References The background	1.Check the documented procedure detailing the background check criteria for an employee or an independent contractor of the CA 2. Verify that the scope of background check contains the details covered in control description	Mandatory	WebTrust 3.3.7, X.509 Policy 5.3.2			

CCA - AUDIT REPORT

	shall be refreshed every three years						
3.5.6.5	The CA shall provide reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations	1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position 2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations and receive regular security/PKI based trainings	Mandatory	WebTrust 3.3			
3.5.6.6	A Certifying Authority must make available to his personnel the Digital Signature Certificate policies it supports, its Certification Practice Statement, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position	1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position 2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations and receive regular security/PKI based trainings	Mandatory	IT CA Rules SCHEDULE III 17			
3.5.6.7	The Certifying Authority must ensure that all personnel performing duties with respect to its operation must: • be appointed in writing; • be bound by contract or statute to the terms and conditions of the position they are to fill; • have received comprehensive training with respect to the duties they are to perform; • be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information; • not be assigned duties that may cause a conflict of	1. For sample CA personnel, perform the following checks: a. personnel received an offer letter with roles and responsibilities appointed in writing. Verify on sample basis for personnel b. personnel is bound by contract or statute to the terms and conditions of the position they are to fill. Verify by checking the contract c. personnel has received comprehensive training via sessions organized specifically for the job. Check training logs d. personnel is bound by statute or contract not to disclose sensitive CA's security related information or subscriber information and has signed NDA for same. e. personnel is not assigned duties that may cause a conflict of interest with their CA's duties f. personnel is aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines	Mandatory	IT CA Rules SCHEDULE III 14			

CCA AUDIT REPORT

	interest with their Certifying Authority's duties; • be aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines framed for carrying out Certifying Authority's operation						

3.5.7. Physical and Operational security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Third Party Access							
3.5.7.1	The external service/facility provider (e.g. outsourcer) shall provide an equivalent level of security controls as required by Information Technology Security Guidelines	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 5.4			
3.5.7.2	In case the Data Centre uses the facilities of external service/facility provider (outsourcer) for any of their operations, the use of external service/facility providers (e.g. outsourcer) shall be evaluated in light of the possible security exposures and risks involved and all such agreements shall be approved by the information asset owner. The external service or facility provider shall also	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 5.4			

COMPLIANCE AUDIT REPORT

	sign non-disclosure agreements with the management of the Data Centre/operational site.						
3.5.7.3	Access to the computer systems by other Organizations shall be subjected to a similar level of security protection and controls as in stated in Information Technology security guidelines under IT CA Rules	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 5.4			
Environmental Protection							
3.5.7.4	Personnel at the operational site shall be trained to monitor and control the various equipment and devices installed at the operational site for the purpose of fire and environment protection	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughou the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rules SCHEDULE II 4			
3.5.7.5	Periodic inspection, testing and maintenance of the equipment and systems shall be scheduled.	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughou the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	T CA Rules SCHEDULE II 4.3			
3.5.7.6	The temperature and humidity condition in the operational site shall be monitored	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughou the operational site	Mandatory	IT CA Rules SCHEDULE II 4.3			

CCA - AUDIT REPORT

	and controlled periodically	and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices					
3.5.7.7	Water detectors shall be installed under the raised floors throughout the operational site and shall be connected to audible alarms	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughou the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rules SCHEDULE II 4.3			
Data Backup and Off-site Retention							
3.5.7.8	The security requirements of backup copies shall be consistent with the controls for the information backed up	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and	Mandatory	WebTrust 4.2.4			

CCA - AUDIT REPORT

		backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.9	Each LAN/system should have a primary and backup operator to ensure continuity of business operations.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rules SCHEDULE II 9			
3.5.7.10	Systems that are completely static may not require periodic backup, but shall be backed up after changes or updates in the information	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be	Mandatory	IT CA Rules SCHEDULE II 9			

CCA AUDIT REPORT

		stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.11	Critical system data and file server software must have incremental backups taken daily.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken	Mandatory	IT CA Rules SCHEDULE II 9			

COPY AUDIT REPORT

		daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.12	The backups shall be kept in an area physically separate from the server. If critical system data on the LAN represents unique versions of the information assets, then the information backups should be rotated on a periodic basis to an off-site storage location.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rules SCHEDULE II 9			
3.5.7.13	The Certifying Authority should verify the integrity of the backups at least once every six months	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented	Mandatory	IT CA Rules SCHEDULE II 9			

CCA AUDIT REPORT

		c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.14	Critical system data and file server software shall have full backups taken weekly.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver	Mandatory	IT CA Rules SCHEDULE II 9			

CCA AUDIT REPORT

		m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.15	Data backup is required for all systems including personal computers, servers and distributed systems and databases.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rules SCHEDULE II 9			
3.5.7.16	Backups of the system, application	1. Conduct walkthrough of the CA backup site and check the following:	Mandatory	IT CA Rules SCHEDULE II 9			

CCA - AUDIT REPORT

	and data shall be performed on a regular basis. Backups should also be made for application under development and data conversion efforts.	a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.17	One set of the original disks for all operating system and application software must be maintained to ensure that a valid, virus-free backup exists and is available for use at any time	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server	Mandatory	IT CA Rules SCHEDULE II 9			

CCA AUDIT REPORT

		software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.18	Backups shall be performed and stored off-site not less than once every 7 days. At least one full backup copy shall be stored at an offsite location (at a location separate from the CA equipment). Only the latest full backup need be retained.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	X.509 Policy 5.1.8			

CCA AUDIT REPORT

3.5.7.19	Full system backups of the CAs, sufficient to recover from system failure, shall be made on a periodic schedule	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	X.509 Policy 5.1.8			
3.5.7.20	Back-up procedures shall be documented, scheduled and monitored.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis	Mandatory	IT CA Rules SCHEDULE II 9			

CCA AUDIT REPORT

		h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up					
3.5.7.21	A Certifying Authority must ensure that facility used for off- site backup shall be within the country and shall have the same level of security as the primary Certifying Authority site	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversionefforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from theserver m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of	Mandatory	WebTrust, IT CA Rules SCHEDULE III 6			

COPY AUDIT REPORT

		business operations q. Security requirements of backup copies are consistent with control for information backed up					
Waste Disposal							
3.5.7.22	All media used for storage of information pertaining to all functions associated with generation, production, issue and management of Digital Signature Certificate shall be scrutinized before being destroyed or released for disposal	associated of DSC is scrutinized before being destroyed or released for disposal. Verify by checking on sample basis, media was disposed off based on defined procedure	Mandatory	IT CA Rules SCHEDULE III 5			
3.5.7.23	Procedures shall be designed and implemented for disposing off sensitive waste material.	1. Verify procedure is present and implemented for disposing off the sensitive waste material 2. Validate all media used for storage of information pertaining to all functions	Mandatory	X.509 Policy 5.1.7, IT CA Rules SCHEDULE III 5			
Power and Air Conditioning							
3.5.7.24	CAs shall have backup power sufficient to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	Mandatory	X.509 Policy 5.1.3			
3.5.7.25	Air-conditioning system and power supply system unit shall be installed by the CA	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	Mandatory	IT CA Rules SCHEDULE II 4.1			
Media Storage							
3.5.7.26	Procedures shall be in place to ensure the secure disposal of sensitive information assets on all corrupted/damaged	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical	Mandatory	IT CA Rules SCHEDULE II 5.2			

CCA AUDIT REPORT

	or affected media both internal (e.g. hard disk/optical disk) and external (e.g. diskette, disk drive, tapes etc.) to the system	control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.27	All items of equipment containing storage media (fixed and removable disks) shall be checked to ensure that they do not contain sensitive data prior to their disposal.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of	Mandatory	WebTrust 3.4.21			

CCSC AUDIT REPORT

		toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.28	Computer media that are being transported to off-site data backup locations should be stored in locked carrying cases that provide magnetic field protection and protection from impact while loading and unloading and during transportation	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly	Mandatory	IT CA Rules SCHEDULE II 8.4			

CCA AUDIT REPORT

		defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.29	There shall be procedures to ensure the authorized and secure transfer to media to/from external parties and the off-site location including a means to authenticate the receipt shall be in place.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical	Mandatory	IT CA Rules SCHEDULE II 8.4			

CCA AUDIT REPORT

		locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.30	Proper records of all movements of computer tapes/disks between on-site and off-site media library must be maintained.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA	Mandatory	IT CA Rules SCHEDULE II 8.4			

CONFIDENTIAL AUDIT REPORT

		location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.31	Media retention periods shall be established and approved by management in accordance with legal regulatory and user requirements.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users.	Mandatory	IT CA Rules SCHEDULE II 8.3			

CONFIDENTIAL REPORT

		Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.32	Procedures shall be in place to ensure that only authorized addition/removal of media from the library is allowed.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed	Mandatory	IT CA Rules SCHEDULE II 8.3			

COPY AUDIT REPORT

		n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.33	All media shall have external volume identification. Internal labels shall be fixed, where available	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer	Mandatory	IT CA Rules SCHEDULE II 8.3			

CCA AUDIT REPORT

		and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.34	All incoming/outgoing media transfers shall be authorized by management and users.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection	Mandatory	IT CA Rules SCHEDULE II 8.3			

CCA AUDIT REPORT

		r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.35	A media management system shall be in place to account for all media stored on-site and off-site	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rules SCHEDULE II 8.3			

CCA AUDIT REPORT

3.5.7.36	Media containing sensitive and back up data must be stored at three different physical locations in the country, which can be reached in few hours. Media that contains audit, archive, or backup information shall be duplicated and stored in a location separate from the CA location.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	X.509 Policy, IT CA Rules			
3.5.7.37	Media containing sensitive and back up data must be stored at three different physical locations in the country, which	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical	Mandatory	X.509 Policy, IT CA Rules			

CCA AUDIT REPORT

	can be reached in few hours. Media that contains audit, archive, or backup information shall be duplicated and stored in a	control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.38	Access to the media library (both on-site and off-site) shall be restricted to the authorized persons only. A list of personnel authorized to enter the library shall be maintained	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of	Mandatory	IT CA Rules SCHEDULE II 8.3			

CCA AUDIT REPORT

		toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.39	Responsibilities for media library management and protection shall be clearly defined and assigned	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly	Mandatory	IT CA Rules SCHEDULE II 8.3			

CCA AUDIT REPORT

		defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.40	Storage media (i.e. floppy diskettes, magnetic tapes, portable hard disks, optical disks, etc.) containing sensitive information shall be secured according to their classification	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical	Mandatory	IT CA Rules SCHEDULE II 5.2			

CCA AUDIT REPORT

		locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.41	Media library, electrical and mechanical control rooms shallbe housed in separate isolated areas, with access granted only to specific, named individuals on a need basis. The area must be fire resistant and free of toxic chemicals	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA	Mandatory	IT CA Rules SCHEDULE II 4.1.8			

CONFIDENTIAL AUDIT REPORT

		location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
3.5.7.42	All sensitive information stored in any media shall bear or be assigned an appropriate security classification.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical andmechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis.Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection areclearly defined and assigned g. Access to the media library isrestricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users.	Mandatory	IT CA Rules SCHEDULE II 5.2			

CONFIDENTIAL REPORT

		Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.					
Inventory Management							
3.5.7.43	All equipment related to CA Operations shall be inventoried	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months.Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	WebTrust 3.4.16			
3.5.7.44	An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months.Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations	Mandatory	IT CA Rules SCHEDULE II 16			

COPY NOT REPORT

		are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory					
3.5.7.45	Details of all media shall be inventoried. An independent physical inventory check of all media shall be conducted at least every six months.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months.Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	IT CA Rules SCHEDULE II 8.3			
3.5.7.46	Inventory control processes and procedures shall be documented and implemented to manage the origination, arrival, condition, departure and destination of each device.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months.Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	WebTrust 4.8.3			
Physical Access							
3.5.7.47	The Certifying Authority must ensure that no single individualmay gain access to the Digital Signature Certificate server and the computer server maintaining all information associated with generation, issue and management of	1. Verify the process of security check to be conducted if the facility housing the CA and CSP equipment is left unattended 2. Validate it covers the requirements mentioned in control description 3. Check the list of persons responsible for doing the security checks mentioned in control - 3.1.4.45 4. Verify if a group of people are assigned the security check responsibility a log identifying the person performing a check at each instance is maintained 5. Check if the facility is not continuously	Mandatory	IT CA Rules SCHEDULE III 12			

COPY AUDIT REPORT

	Digital Signature Certificate and private keys of the Certifying Authority. Minimum two individuals, preferably using a split-knowledge technique, such as twin passwords, must perform any operation associated with generation, issue and management of Digital Signature Certificate and application of private key of the Certifying Authority.	attended, the last person to depart initials a sign-out sheet that indicates the date and time, and asserts that all necessary physical protection mechanisms are in place and activated					
3.5.7.48	Removable cryptographic modules shall be deactivated prior to storage. When not in use, removable cryptographic modules, activation information used to access or enable cryptographic modules shall be placed in secure containers. Activation data shall either be memorized, or recorded and stored in a manner commensurate with the security afforded the cryptographic module, and shall not be stored with the cryptographic module.	1. Verify removable cryptographic modules are deactivated before storage 2. Validate activation information used to access or enable cryptographic modules is placed in secure containers. 3. Check the mechanism used to store activation data	Mandatory	X.509 Policy 5.1.2.1			
3.5.7.49	Two person physical access control shall be present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates.	Mandatory	X.509 Policy 5.1.2.			

CCA AUDIT REPORT

		Practical demonstration of the two person physical access should be done in the presence of the auditor.					
3.5.7.50	Unauthorized access to areas storing hardware shall be prohibited	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.	Mandatory	X.509 Policy 5.1.2.1			
3.5.7.51	Emergency exits shall be tested periodically to ensure that the access security systems are operational	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.	Mandatory	IT CA Rules CHEDULE II 4.4			
3.5.7.52	Computer System or PKI Server performing the Digital Signature Certification functions shall be dedicated to those functions and should not be used for any other purposes.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits.	Mandatory	IT CA Rules SCHEDULE III 3.11			

CCA IN AUDIT REPORT

		d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.					
3.5.7.53	Intrusion detection systems shall be used to monitor andrecord physical access to the Digital Signature Certification system during and after office hours.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.	Mandatory	IT CA Rules SCHEDULE III 3.10			
3.5.7.54	By-pass or deactivation of normal physical security arrangements shall be authorized and documented by security personnel	1. Verify all By-pass or deactivation ofnormal physical security arrangements is authorized and documented by security personnel	Mandatory	IT CA Rules SCHEDULE III 3.9			
3.5.7.55	Access to infrastructure components essential to operation of Certifying Authority such as power control panels, communication infrastructure, Digital Signature Certification system, cabling, etc. shall be restricted to authorized personnel.	1. Verify list of personnel with access to essential components for CA is maintained 2. Validate no unauthorized personnel has access to these components by checking the controls implemented to prevent unauthorized access such as locked door, biometric etc.	Mandatory	IT CA Rules SCHEDULE III 3.8			
3.5.7.56	Access to PKI Server, root keys or	1. Verify Alarm and intrusion detection system are installed at every stage with	Mandatory	IT CA Rules SCHEDULE III 3.4			

CCA - AUDIT REPORT

	any personal computer system or network device shall be prohibited	adequate power backup 2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited					
3.5.7.57	Electrical/Electronic circuits to external security alarm monitoring service (if used) shall be supervised	1. Verify Alarm and intrusion detection system are installed at every stage with adequate power backup 2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited	Mandatory	IT CA Rules SCHEDULE III 3.4			
3.5.7.58	Alarm and intrusion detection system must be installed at every stage with adequate power backup capable of continuing operation even in the event of loss of main power.	1. Verify Alarm and intrusion detection system are installed at every stage with adequate power backup 2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited	Mandatory	IT CA Rules SCHEDULE III 3.4			
3.5.7.59	Each security zone must be separated from the other by floor to ceiling concrete reinforced walls.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the	Mandatory	IT CA Rules SCHEDULE III 3.4			

COMPLIANCE AUDIT REPORT

		same 6. Collect site access log and verify all entries are recorded and inspected periodically					
3.5.7.60	A multi-tiered access mechanism must be installed at the Certifying Authority's operational site. The facility should have clearly laid out security zones within its facility with well-defined access rights to each security zone.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically	Mandatory	IT CA Rules SCHEDULE III 3.4			
3.5.7.61	A site access log shall be maintained at the Certifying Authority's operational site and inspected periodically. All personnel entering and leaving CA operational facilities shall be logged (i.e., an audit trail of all access is securely maintained).	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made.	Mandatory	WebTrust 3.4.11, IT CA Rules SCHEDULE III 3.3			

CCA - AUDIT REPORT

		c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically					
3.5.7.62	Any personnel not on the access list shall be properly escorted and supervised at all times within the operational site premises. All individuals, other than operations staff, shall sign in and sign out of the operational site and shall be accompanied by operations staff.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically	Mandatory	IT CA Rules IT CA Rules SCHEDULE- III 3.9, SCHEDULE II 4.4			
3.5.7.63	An up-to-date list of personnel who possess the cards/keys shall be regularly maintained	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and	Mandatory	IT CA Rules SCHEDULE- III 3.8			

CCA - AUDIT REPORT

	and archived for a period of three years. Loss of access cards/keys shall be reported immediately to the Security Administrator; who shall take appropriate actions to prevent unauthorized access.	archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically					
3.5.7.64	An inventory of access cards shall be maintained by the CA and periodically reviewed	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list	Mandatory	IT CA Rules SCHEDULE- III 3.7			

CCA IT AUDIT REPORT

		for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically					
3.5.7.65	Access security system shall be installed to control and audit details of personnel using the Digital Signature Certification System.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rules SCHEDULE- III 3.6			
3.5.7.66	Unescorted access to Certifying Authority's server shall be limited to	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same	Mandatory	IT CA Rules SCHEDULE- III 3.3			

CCA - AUDIT REPORT

	those personnel identified on an access list	2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.67	A manned reception area or other means to control physical access should be present at the CA operations site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates	Mandatory	WebTrust 3.4.3			

CCA - AUDIT REPORT

		in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.68	Physical access to CA facilities and equipment should be limited to authorized individuals, protected through restricted security perimeters, and shall be operated under multiple person (at least dual custody) control. Personnel authorized for limited physical access shall not be allowed to gain unauthorized access to restricted area within operational site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel	Mandatory	WebTrust 4.8.3, IT CA Rules SCHEDULE- II 4.4			

CONFIDENTIAL REPORT

		for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.69	Unauthorized intrusion shall be manually or electronically monitored at all times at the CAs Site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rules SCHEDULE- II 3.4.6			

CCA AUDIT REPORT

3.5.7.70	Biometric physical access security systems shall be installed to control and audit access to the operational site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rules SCHEDULE- II 4.4			
3.5.7.71	Entrance to the main building where the Certifying Authority's facilities such as Data Centre, PKI Server and Network devices are housed and entrance to each security zone shall be video recorded round the clock. The recording	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and	Mandatory	IT CA Rules SCHEDULE- III 3.5			

CCA AUDIT REPORT

	must be carefully scrutinized and maintained for at least one year	entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.72	Dual control over the inventory and issue of access cards/keys during normal business hours to the Data Centre shall be in place.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same	Mandatory	IT CA Rules SCHEDULE- II 4.4			

CCA AUDIT REPORT

		g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.73	All Certifying Authority personnel must have their identity and authorization verified before they are included in the access list for physical access to the Certifying Authority's system. All personnel are required to wear visible identification. Employees are encouraged to challenge anyone not wearing visible identification	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel	Mandatory	WebTrust 3.4.9 IT CA Rules SCHEDULE-			

COPY NOT REPORT

		allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.5.7.74	Responsibilities round the clock, seven days a week, three hundred sixty five days a year for physical security of the systems used for operation and also actual physical layout at the site of operation shall be defined and assigned to named individuals	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited toauthorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in theoperation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rules SCHEDULE- II 4.4, CA Browser Forum 5.1.2			
Fire Protection							
3.5.7.75	Fire doors exist on security perimeters	1. Conduct walkthrough to check the following:	Mandatory	WebTrust 3.4.6			

CCA - AUDIT REPORT

	around CA operational facilities and are alarmed and conform to local fire regulations.	a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis					
3.5.7.76	Periodic training and fire drills shall be conducted	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE- II 4.2			
3.5.7.77	Procedures for the safe evacuation of personnel in anemergency shall be visibly pasted/displayed at prominent places at the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are	Mandatory	IT CA Rules SCHEDULE- II 4.2			

CCA - AUDIT REPORT

		prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis					
3.5.7.78	The work areas shall be kept clean at all times.	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE- II 4.2			
3.5.7.79	There shall be no eating, drinking or smoking in the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE- II 4.2			
3.5.7.80	Periodic testing, inspection and	1. Conduct walkthrough to check the following:	Mandatory	IT CA Rules SCHEDULE- II 4.3			

CCA - AUDIT REPORT

	maintenance of the fire equipment and fire suppression systems should be carried out.	a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis					
3.5.7.81	Fire extinguishers shall be installed at the operational site and their locations clearly marked with appropriate signs	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE- II 4.2			
3.5.7.82	Automatic fire detection, fire suppression systems and audible alarms as prescribed by the Fire Brigade or any other agency of the Central or State Government shall be installed at the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are	Mandatory	IT CA Rules SCHEDULE- II 4.2			

CCA - AUDIT REPORT

		prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis					
3.5.7.83	No combustible materials shall be stored within hundred meters of the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE- II 4.2			
Site Location & Design							
3.5.7.84	CA shall ensure exact location of Digital Signature Certification System shall not be publicly identified	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in	Mandatory	IT CA Rules SCHEDULE- III 3.3			

CCA AUDIT REPORT

		separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.5.7.85	All removable media and papers containing sensitive or plain text information shall be listed, documented and stored in a container properly identified in the CA Facilit	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rules SCHEDULE- III 3.3			
3.5.7.86	Any facility that supports mission-	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities	Mandatory	IT CA Rules SCHEDULE- II 4.1.9			

CCA - AUDIT REPORT

	critical and sensitive applications must be located and designed for reparability, relocation and reconfiguration. The ability to relocate, reconstitute and reconfigure these applications must be tested as part of the business continuity/disaster recovery plan.	used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.5.7.87	Media library, electrical and mechanical control rooms shall be housed in separate isolated areas, with access granted only to specific, named individuals on a need basis	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage	Mandatory	IT CA Rules SCHEDULE- II 4.1.8			

CCA - AUDIT REPORT

		f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.5.7.88	Air-conditioning system, power supply system and uninterrupted power supply unit with proper backup shall be installed depending upon the nature of operation. All ducting holes of the air-conditioning system must be designed so as to prevent intrusion of any kind.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rules SCHEDULE- II 4.1.6			

CCA - AUDIT REPORT

3.5.7.89	CA Shall ensure all external walls shall be constructed of brick or reinforced concrete of sufficient thickness to resist forcible attack. Ground level windows shall be fortified with sturdy mild steel grills or impact-resistant laminated security glass. All internal walls must be from the floor to the ceiling and must be tamper-evident	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rules SCHEDULE- II 4.1.5			
3.5.7.90	Construction shall be done in compliance with all applicable building and safety regulations as laid down by the relevant Government agencies with use of fire resistant material and non-toxic chemicals.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed	Mandatory	IT CA Rules SCHEDULE- II 4.1.3			

CCA AUDIT REPORT

		e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.5.7.91	The location and construction of the facility housing CA and Certificate Status Provider (CSP) equipment shall be consistent with facilities used to house high value, sensitive information. The site shall not be in locations that are prone to natural or man-made disasters, like flood, fire, chemical contamination and explosions	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	X.509 Policy 5.1.1, IT CA Rules SCHEDULE- III 3.1			

CCA AUDIT REPORT

3.5.8. Information Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Prevention of Computer Misuse							
3.5.8.1	Procedure shall be set-up to establish the nature of any alleged abuse and determine the subsequent action required to be taken to prevent its future occurrence	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE- II 5.5			
3.5.8.2	All incidents related to breaches shall be reported to the System Administrator or System Security Administrator for appropriate action to prevent future occurrence. These will be responsible for investigation and follow up action	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE- II 5.5			
3.5.8.3	Effective measures including reporting of suspected breach, investigation and remedial measures shall be established	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator	Mandatory	IT CA Rules SCHEDULE- II 5.5			

COPY - AUDIT REPORT

		d. Procedure to prevent future occurrence of an incident					
3.5.8.4	CA shall ensure adequate information is provided to all persons, including management, systems developers and programmers, end-users, and third party users warning them against misuse of computers.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE- II 5.5			
3.5.8.5	Prevention, detection, and deterrence measures shall be implemented to safeguard the security of computers and computer information from misuse. The measures taken shall be properly documented and reviewed regularly.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE- II 5.5			
3.5.8.6	The computer system shall be configured with minimum of the required accounts and network services.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	X.509 Policy 6.5.1			
Sensitive Information Security							
3.5.8.7	Removable	1. Refer the Process for handling classified	Mandatory	IT CA Rules SCHEDULE- II			

CCA - AUDIT REPORT

	electronic storage media must be removed from the computer and properly secured at the end of the work session or workday.	data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday		5.3			
3.5.8.8	Sensitive information and data, which are stored on the fixed disk of a computer shared by more than one person, must be protected by access control software (e.g., password). Security packages must be installed which partition or provide authorization to segregated directories/files.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday	Mandatory	IT CA Rules SCHEDULE- II 5.3			
3.5.8.9	Highly sensitive information shall be classified in accordance as per Control No. 3.1.2.1	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday	Mandatory	IT CA Rules SCHEDULE- II 5.3			
3.5.8.10	Highly sensitive information assets shall be stored on secure removable media and should be in an encrypted format to avoid compromise by unauthorized persons.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is	Mandatory	T CA Rules SCHEDULE- II 5.3			

COA - AUDIT REPORT

		removed from the computer and properly secured at the end of the work session or workday					
Sensitive Information Control							
3.5.8.11	The Certifying Authority shall disclose information on the assurance levels of the certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	1. Verify the CA manages its functions in accordance with the levels of integrity and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	Mandatory	IT Regulations 3			
3.5.8.12	The Certifying Authority shall manage its functions in accordance with the levels of integrity and security approved by the Controller from time to time	1. Verify the CA manages its functions in accordance with the levels of integrity and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	Mandatory	IT Regulations 3			
3.5.8.13	Electronic communication systems, such as router, switches, network device and computers, used for transmission of sensitive information should be equipped or installed with suitable security software and if necessary with an encryptor or encryption software. The appropriate procedure in this regard shall be documented	1. Obtain documented procedure to ensure safety of communication systems 2. Obtain list of communication systems (i.e. router, switches & computers) used for transmission of sensitive information 3. Verify security implementation in devices is done as per the procedure	Mandatory	IT CA Rules SCHEDULE- II 5.2			
System Administration							
3.5.8.14	The System Administrator should ensure that no generic user is enabled or active on the system	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security	Mandatory	IT CA Rules SCHEDULE- II 5.1			

COPY AUDIT REPORT

		Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.15	The System Administrator shall ensure that the data, file andPublic Key Infrastructure (PKI) servers are not left unmonitored while these systems are powered on	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and	Mandatory	IT CA Rules SCHEDULE- II 5.1			

COA AUDIT REPORT

		verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.16	The System Administrator together with the system support staff, shall conduct a regular analysis of problems reported to and identify any weaknesses in protection of the information	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active	Mandatory	IT CA Rules SCHEDULE- II 5.1			
3.5.8.17	All security violations must be recorded, investigated, and periodic status reports compiled for review by the management	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator	Mandatory	IT CA Rules SCHEDULE- II 5.1			

COA - AUDIT REPORT

		d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.18	The System Administrator must authorize privileged access to users only on a need-to-know and need-to-do basis and also only after the authorization is documented.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording,	Mandatory	IT CA Rules SCHEDULE- II 5.1			

COPY - AUDIT REPORT

		investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.19	The System Administrator must take steps to safeguards classified information as prescribed by its owner.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active	Mandatory	IT CA Rules SCHEDULE- II 5.1			
3.5.8.20	The System Administrator shall promptly disable access to a user's account if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access. Reactivation of the	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely	Mandatory	IT CA Rules SCHEDULE- II 5.1			

CCA - AUDIT REPORT

	user's account must be authorized in writing by the System Administrator (Digitally signed E-mail may be acceptable)	responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.21	A system for password management should be put in place to cover the eventualities such as forgotten password or changeover to another person in case of System Administrato (or System Security Administrator) leaving the organization. Every instance of usage of administrator's passwords must be documented.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews	Mandatory	IT CA Rules SCHEDULE- II 5.1			

COMPTROLLER AUDIT REPORT

		done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.22	The system administration's password and operation of trusted services must not be written down (in paper or electronic form) or shared with anyone.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active	Mandatory	IT CA Rules SCHEDULE- II 5.1			
3.5.8.23	System Administrator shall solely be responsible for creating, classifying, and retrieving, modifying, deleting or archiving information.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information	Mandatory	IT CA Rules SCHEDULE- II 5.1			

CCA AUDIT REPORT

		3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.24	CA shall ensure System Security Administrator is properlytrained before assigning the system security responsibilities	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.	Mandatory	IT CA Rules SCHEDULE- II 5.1			

CCA AUDIT REPORT

		10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.5.8.25	The System Administrator may have a designated System Security Administrator who will assume security responsibilities and provide physical, logical and procedural safeguards for information	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active	Mandatory	IT CA Rules SCHEDULE- II 5.1			
3.5.8.26	The CA shall designate a trained "System Administrators" who will ensure that the protective security measures of the system are functional and who will maintain the security posture of CA's organization	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy	Mandatory	IT CA Rules SCHEDULE- II 5.1			

CCA - AUDIT REPORT

		4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					

3.5.9. Information Classification

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Information Classification							
3.5.9.1	CA shall ensure information labeling and handling are performed in accordance with the CA's information classification documented procedures basis following categories: • Confidential • Restricted • Internal • Unclassified • Top Secret • Secret • Confidentiality • Restricted • Unclassified	1. Obtain copy of the process for handling classified data 2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data c. Information is labeled in accordance with CA's information classification documented procedures	Mandatory	WebTrust 3.2.4			
3.5.9.2	Documented processes shall be created for classification, declassification, labeling, storage, access, destruction and reproduction of	1. Obtain copy of the process for handling classified data 2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data	Mandatory	IT CA Rules 19.1, WebTrust			

CCA AUDIT REPOR

	classified data.	c. Information is labeled in accordance with CA's information classification documented procedures					

3.5.10. Implementation of Information Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Training							
3.5.10.1	All individuals responsible for trusted roles shall be made aware of any significant changes in the CA, ESP CSP, or RA operations, as applicable.	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	X.509 Policy 5.3.4 CA Browser Forum 5.3.4			
3.5.10.2	All Validation Specialists shall pass an examination provided by the CA on the information verification requirements	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to	Mandatory	CA Browser Forum 5.3.3			

CC AUDIT REPORT

		maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels					
3.5.10.3	CA shall ensure personnel entrusted with Validation Specialist duties maintain a skill level that enables them to perform such duties satisfactoril	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	CA Browser Forum 5.3.3			
3.5.10.4	Refresher training must be conducted as and when required, and the Certifying Authority must review these requirements at least once a year. Records of all trainings shall be maintained and reviewed periodically	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to	Mandatory	IT CA Rules SCHEDULE III 16 CA Browser Forum 5.3.3			

CCA - AUDIT REPORT

		maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels					
3.5.10.5	The CA shall ensure all personnel performing duties with respect to operation of a CA,ESP, CSP shall receive comprehensive training covering the following: 1. CA/ESP/CSP/RA security principles and mechanisms 2. All PKI software versions in use on the CA system 3. All PKI duties they are expected to perform 4. Disaster recovery and business continuity procedures	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	X.509 Policy 5.3.3, IT CA Rules SCHEDULE-III.15			
Risk Assessment							
3.5.10.6	Hypervisors, operating system, database, and network device patches and updates shall be applied in a timely manner when deemed necessary based on a risk assessment and follow formal change management procedures	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any	Mandatory	WebTrust 3.6.18			

CCA AUDIT REPORT

		scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed					
3.5.10.7	A security plan shall be developed covering the following: • Security procedures to manage the risks • administrative, organizational, technical, andphysical safeguards • cost of implementing the specific measures • security breach plan in case of any incidents	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed	Mandatory	CA Browser Forum 5			
3.5.10.8	The sufficiency of the policies, procedures, information systems, technology, and other arrangements that the CA has in place to counter cyber threats shall be verified.	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner	Mandatory	CA Browser Forum 5			

CCA AUDIT REPORT

		3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed					
3.5.10.9	A list of foreseeable internal and external threats that could result in unauthorized access, disclosure, misuse, alteration, or destruction of any critical information shall be maintained.	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed	Mandatory	CA Browser Forum 5			
3.5.10.10	The CA's security program shall include an annual Risk Assessment	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational,	Mandatory	IT CA Rules SCHEDULE-II 17.3 CA Browser Forum 5			

CC AUDIT REPORT

		c. technical, and d. physical 4. Verify formal change management procedures have been developed					
Self-Assessment							
3.5.10.11	Self-Assessment shall be performed on a periodic basis and the findings shall be reported to management and discussed for closure	1. Obtain the self-assessment plandeveloped by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address thefinding	Mandatory	IT CA Rules 2.e			
3.5.10.12	A documented security self-assessment plan shall be prepared by the CA	1. Obtain the self-assessment plandeveloped by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address thefinding	Mandatory	IT CA Rules 2.e			
Security Policy							
3.5.10.13	Test2	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by	Optional	Hello			

CCA - AUDIT REPORT

		checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.14	Any change made by the Certifying Authority in the security policy shall be submitted by it within two weeks to the Controller	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined	Mandatory	IT CA Rules 19			

CCA - AUDIT REPORT

		4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.15	A review process shall be designed for maintaining the security policy. Review dates and responsibilities should be recorded.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks	Mandatory	WebTrust 3.1.3			
3.5.10.16	An authorized personnel shall be responsible for ensuring that security procedures within their area of	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the	Mandatory	WebTrust 3.9.8			

CCA - AUDIT REPORT

	responsibility are carried out correctly	policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.17	The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and security breaches. The security policy shall be approved by management,published and communicated to all employees.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential	Mandatory	IT Regulations 3, WebTrust 3.1.1			

CCA - AUDIT REPORT

		information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.18	The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and security breaches. The security policy shall be approved by management,	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been	Mandatory	IT Regulations 3, WebTrust 3.1.1			

CCA - AUDIT REPORT

		communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.19	CA shall ensure the security policy clearly addresses security of both confidential and non-confidential information. The Certifying Authority shall prepare detailed manuals for performing all its activities and shall scrupulously adhere to them.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last	Mandatory	WebTrust 3.9.5, IT Regulations 3			

CCA - AUDIT REPORT

		audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.5.10.20	An information security policy document has been formulated that includes physical, personnel, procedural and technical controls and was submitted to the Controller before commencement of operation.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks	Mandatory	IT CA Rules 19.2			

1. Annual Audit Period Details

S. No.	Description	From	To	Brief details of open observation (max 50 words)
Auditor Remarks:				

CCA - AUDIT REPORT

2. Internal Audit Details

S. No.	Description	From	To	Brief details of open observation (max 50 words)	Details of Auditors
Auditor Remarks:					

3. eKYC Account Audit Details of last one year - Month-wise

S. No.	Month	From	To	Summary of Observations	Details of Auditors
Auditor Remarks:					

4. eKYC Account-based Verification Enabled by CA - Details of the Audit Period

S. No.	Option	Date of Approval by CCA	No DSCs Issued	Associated External Service	Details of External Service
Auditor Remarks:					

5. RA Audit Details – During the Annual Audit Period

S. No.	Description	Details
1	Number of RAs	Total RAs - Active RAs -
2	Dates of RA Audit	
3	Details of Non-Compliance reported by RAs	)
4	Action Taken by CAs	
Auditor Remarks:		

6. No of Court Cases / Police Complaints

S. No.	Description	Details
1	Number of active court cases related to verification prior to issuance of DSC (Exists before the audit period)	
2	Number of court cases related to verification prior to issuance of DSC (Registered during the audit period)	
3	Number of police complaints against CA on DSC issuance/verification related activities	
Auditor Remarks:		

7. No of Revocation of DSC during the Audit Period

CCA - AUDIT REPORT

S. No.	Description	Details
1	Number of DSCs revoked	
2	Number of revocation requests received from subscriber/organizations & reasons	
3	Number of DSCs revoked by CAs & reasons	)
Auditor Remarks:		

8. Empanelment of Crypto Token

S. No.	Brand Name of Token	Details of OEM	Make in India Percentage	FIPs Certification up to	Details of Security Audit Details of Crypto token
Auditor Remarks:					

9. Details of CA Software/Website

S. No.	Description	Developed By	Database Used	Certification	Last Security Audit
Auditor Remarks:					

10. Details of DC & DR Site

S. No.	Description	Location	No of System Administrators	No of CA Operators	No of Verification Officers	Total CA Manpower
Auditor Remarks:						

11. Details of CA Services

S. No.	Description	Internal Only	External Service	No of ASPs/ Organizations
Auditor Remarks:				

12. Details of ASP

S. No.	Description	Details
1	No of ASPs	
2	No of ASPs whose audit exceed more than One year	
Auditor Remarks:		

13. Public Information maintained at the website of CA

S. No.	Description	Website Link

COPY - AUDIT REPORT

Auditor Remarks:

14. Cost of Certificates issued during audit period

S. No.	Description	Details
1	Average expenditure for issuance of one DSC and maintenance of the details for a period of 7 years after expiry of DSC	
2	Average fee charged for one DSC by CA	
3	Detailed explanation, sustainability plan if the average fee charged is less than average cost of certificates	
Auditor Remarks:		

15. CA Self-assessment for audit period

S. No.	Name	Details
1	No of DSC issued without any DSC application Forms, if any & reason for non-compliance.	
2	No of DSC issued without charging fee, if any & details.	
3	No DSC issued without having physical verification(video/Biometric Aadhaar) if any	
4	No of DSC issued(except for foreign nationals) whose name is not matching with as that of in Aadhaar or PAN, if any & reason for noncompliance	
5	Whether CA system allows sending common OTP to many customers? If Yes, reason for such non-compliance	
6	Whether access to CA system is based on single URL-point or allows Link based access. If link-based access allowed, provide details in respect of coverage of such access in the security audit, annual audit & internal audit. The details of vulnerabilities and non-compliance noted for each type of links.	
7	The effort taken by CA to find out the own-noncompliance and action Taken during the audit period.	
Auditor Remarks:		

16. CA Software and external connectivity

S. No.	Name	Details
Auditor Remarks:		

15. CA Self-assessment for audit period

S. No.	Name	Details
1	Total service down time during the audit period, if any.	
2	Reason for non-availability of service and remedial measures taken.	
Auditor Remarks:		

18. List of CA Trusted Persons

S. No.	Name	Designation	Location of Posting DC/DR	Role in CA	ID Card No & Mobile	Identification Details in the CA Payroll	Employed Since	Training details	Date of last background verification

CA - AUDIT REPORT

Auditor Remarks:

CCA - AUDIT REPORT

AXIS BANK

Transaction Details

GAURAV SINGH

Transaction Details

From Account :	XXXXXXXXXXX8604
Amount :	Rs.50000
Nick Name :	Gaurav
Payee Account No:	XXXXXXXX5244
Payee Bank :	CANARA BANK
IFSC:	CNRB0001956
Payee Name :	GAURAV SINGH NIRJA SINGH
Payment Mode :	NEFT
Frequency :	One time
Remarks:	
Reference No:	QH496CJP1503
Payment Status :	In Progress
Date:	05 Jun 2026

CCA - AUDIT REPORT

Disclaimer: Your payment request has been received and is currently being processed. The final status is subject to confirmation from the beneficiary bank. Axis Bank shall not be held liable for any delays or failures in acknowledgment from the beneficiary bank.